WOJSKOWA AKADEMIA TECHNICZNA

im. Jarosława Dąbrowskiego

WYDZIAŁ CYBERNETYKI



PRACA DYPLOMOWA

STUDIA I°

Temat pracy: **SYSTEM OCHRONY APLIKACJI INTERNETOWEJ PRZED ATAKAMI DOS Z WYKORZYSTANIEM ROZWIĄZANIA F5 BIG-IP I MECHANIZMÓW TAKICH JAK IRULES**

KRYPTOLOGIA I CYBERBEZPIECZEŃSTWO

(kierunek studiów)

Dyplomant:

Tymoteusz KOŚCIUSZKO

Promotor:

mgr inż. Krystian WOJDYGOWSKI

Warszawa 2026

Spis treści

Wstęp 4
Rozdział I. Charakterystyka ataków DoS i przegląd dostępnych narzędzi zapobiegających tym atakom 5
I.1. Charakterystyka aplikacji internetowych 5
I.2. Charakterystyka ataków DoS 7
I.2.1. Definicja ataku DoS i jego cele 7
I.2.2. Ataki DDoS i różnice względem DoS 8
I.2.3. Klasyfikacja ataków DoS i narzędzia ataku 9
I.3. Narzędzia i technologie ochrony przed atakami DoS 11
I.3.1. Tradycyjne rozwiązania bezpieczeństwa 11
I.3.2. Przegląd zaawansowanych rozwiązań ochrony przed DoS 13
I.3.3. Strategie obrony wielowarstwowej 14
Rozdział II. Analiza funkcji oferowanych przez urządzenie F5 BIG-IP 15
II.1. Firma F5 Inc. – profil działalności i oferowane rozwiązania 15
II.2. Charakterystyka i architektura platformy F5 BIG-IP 17
II.3. Moduły systemu BIG-IP dedykowane ochronie przed atakami DoS 19
Rozdział III. Opracowanie projektu systemu ochrony aplikacji internetowej 21
III.1. Opis dotychczasowej infrastruktury 21
III.2. Cele i założenia projektowe 22
III.3. Wymagania funkcjonalne 22
III.4. Wymagania niefunkcjonalne 23
III.5. Projekt systemu ochrony 23
Rozdział IV. Wdrożenie i konfiguracja systemu ochrony 25
IV.1. Wstępna konfiguracja maszyny wirtualnej i BIG-IP 25
IV.2. Konfiguracja modułu LTM i dodanie serwera aplikacji 27
IV.3. Konfiguracja polityki ochrony przed atakami DoS 30
IV.3.1. Mitygacja ataków na warstwę aplikacyjną (L7) 31
IV.3.2. Mitygacja ataków na warstwę sieciową i transportową (L3 i L4) 35
IV.4. Dodatkowa konfiguracja ochrony przy pomocy skryptów iRules 38
IV.5. Konfiguracja systemu monitorowania zdarzeń 39

Rozdział V. Przeprowadzenie testów i opracowanie wniosków 40
V.1. Środowisko testowe i metodyka badań 40
V.2. Badanie odporności serwera bez systemów ochrony 41
V.2.1. Podatność na ataki w warstwie L3 i L4 41
V.2.2. Podatność na ataki w warstwie L7 44
V.3. Badanie skuteczności mitygacji ataków DoS z wykorzystaniem F5 BIG-IP 47
V.3.1. Test ataku w warstwie L3 i L4 48
V.3.2. Test ataku w warstwie L7 50
Wnioski końcowe 52
Bibliografia 53
Spis rysunków 55
Spis tabel 56
Załączniki 56

Wstęp

Współczesna gospodarka oraz codzienne funkcjonowanie społeczeństwa są nierozerwalnie związane z infrastrukturą teleinformatyczną, która w ostatnich dekadach ewoluowała do rangi zasobu krytycznego. W środowisku, gdzie procesy biznesowe realizowane są w czasie rzeczywistym, gwarancja dostępności usług stała się de facto priorytetem. Uzależnienie kluczowych sektorów państwa i biznesu od ciągłości działania systemów IT stworzyło jednak idealne warunki dla cyberprzestępców, dla których ataki odmowy usługi oraz ich rozproszone warianty stanowią skuteczne narzędzie destabilizacji.

Ewolucja zagrożeń sieciowych wymusiła zmianę paradygmatu obrony – proste mechanizmy filtrowania pakietów ustąpiły miejsca bardziej zaawansowanym rozwiązaniom, zdolnym do głębokiej inspekcji ruchu i odróżniania użytkownika od automatu lub wroga. Niniejsza praca inżynierska podejmuje ten problem, prezentując proces projektowania i wdrażania kompleksowej ochrony dla podatnej aplikacji internetowej przy użyciu wiodącej w branży platformy BIG-IP firmy F5.

Układ pracy został podzielony na pięć rozdziałów, które logicznie prowadzą od podstaw teoretycznych (rozdziały 1 i 2), przez założenia projektowe (rozdział 3), aż po wytworzenie i weryfikację rozwiązania (rozdział 5).

Rozdział pierwszy stanowi wprowadzenie teoretyczne do tematyki aplikacji internetowych oraz charakterystyki ataków DoS, klasyfikując wektory zagrożeń i omawiając narzędzia wykorzystywane zarówno przez atakujących, jak i obrońców.

W rozdziale drugim szczegółowo scharakteryzowano platformę sprzętową i programową F5 BIG-IP, wyjaśniając funkcjonalność kluczowych modułów bezpieczeństwa: LTM, AFM oraz ASM.

Rozdział trzeci definiuje środowisko projektowe przedsiębiorstwa, prezentując analizę stanu obecnego infrastruktury, identyfikację luk bezpieczeństwa oraz sformułowanie wymagań funkcjonalnych i niefunkcjonalnych dla nowego systemu ochrony.

W rozdziale czwartym opisano proces implementacji rozwiązania, obejmujący konfigurację środowiska wirtualnego, budowę topologii sieciowej oraz dostrajanie polityk bezpieczeństwa dla ataków w warstwach L3, L4 i L7.

Rozdział piąty zawiera opis przeprowadzonych ataków testowych, prezentując analizę porównawczą odporności serwera przed i po wdrożeniu mechanizmów obronnych, co pozwoliło na ostateczną weryfikację rozwiązania i wyciągnięcie wniosków końcowych.

Rozdział I. Charakterystyka ataków DoS i przegląd dostępnych narzędzi zapobiegających tym atakom

I.1. Charakterystyka aplikacji internetowych

Podjęcie tematu bezpieczeństwa systemów webowych, a szczególnie ich odporności na ataki odmowy usługi (DoS, z ang. *Denial of Service*), które stanowią główny przedmiot niniejszej pracy, wymaga w pierwszej kolejności precyzyjnego zdefiniowania pojęć standardowej witryny WWW oraz aplikacji internetowej. Uprzednio jednak należałoby nakreślić szerszy kontekst środowiska ich funkcjonowania – sieci Internet.

We współczesnym świecie Internet przestał być jedynie narzędziem do wymiany informacji naukowych oraz rozrywkowych, stając się fundamentalnym elementem życia codziennego i infrastruktury krytycznej. Jego rola ewoluowała na przestrzeni lat w stronę uniwersalnego medium, które pośredniczy w niemal każdym aspekcie funkcjonowania społeczeństwa – od komunikacji i rozrywki, przez edukację i pracę zdalną, aż po kluczowe operacje gospodarcze i administracyjne. W obliczu tej powszechnej cyfryzacji stabilność i dostępność usług sieciowych nabrały kluczowego znaczenia dla bezpieczeństwa ekonomicznego i społecznego zarówno państw, jak i organizacji.

Niemniej jednak, tak wysoki stopień uzależnienia od infrastruktury sieciowej generuje nowe, niespotykane wcześniej kategorie zagrożeń. Globalny charakter Internetu, przy jednoczesnym zapewnieniu względnej anonimowości, stworzył dogodne warunki dla rozwoju cyberprzestępczości. Zagrożenia te nie ograniczają się już tylko do kradzieży tożsamości czy złośliwego oprogramowania – ewoluowały one w kierunku zorganizowanych działań mających na celu paraliż całych systemów usługowych, wymuszenia okupów czy destabilizację konkurencji. [1] W tym skądinąd niebezpiecznym środowisku głównym punktem kontaktu użytkownika z siecią (a tym samym głównym celem ataków) stały się systemy webowe.

Aby zrozumieć specyfikę ochrony tych systemów, należy dokonać rozróżnienia między ich dwoma podstawowymi typami. Pojęciem wyjściowym jest witryna WWW (z ang. *World Wide Web*). W ujęciu technicznym definiuje się ją jako zbiór powiązanych ze sobą dokumentów hipertekstowych, plików graficznych oraz multimedialnych, które są udostępniane pod wspólną domeną internetową. Podstawową cechą klasycznej witryny jest jej statyczny charakter – służy ona przede wszystkim do jednostronnej prezentacji informacji. Użytkownik (klient) pobiera jedynie treść przygotowaną wcześniej przez autora, a jego interakcja ogranicza się w dużej mierze do nawigacji pomiędzy podstronami za pomocą hiperłączy. Architektura takiej witryny opiera się na prostym żądaniu pliku z serwera i wyświetleniu go w przeglądarce, bez skomplikowanego przetwarzania danych.

W przeciwieństwie do witryny WWW, aplikacja internetowa to – zgodnie ze współczesną literaturą przedmiotu – oprogramowanie osadzone na serwerze i działające

w architekturze klient-serwer, w którym przeglądarka pełni rolę interfejsu użytkownika (tzw. *frontend*), natomiast kluczowa logika biznesowa oraz przetwarzanie danych odbywają się po stronie serwera (tzw. *backend*) lub są rozproszone w chmurze obliczeniowej. Najważniejszą zaletą aplikacji internetowej ponad zwykłą stronę WWW jest jej interaktywność oraz dwukierunkowy przepływ informacji. Użytkownik takiej aplikacji nie jest bowiem jedynie biernym odbiorcą treści, lecz aktywnie wprowadza dane, które są następnie przetwarzane, zapisywane w bazach danych i modyfikują stan systemu w czasie rzeczywistym.

Kluczowe rozbieżności między tymi dwoma systemami sprowadzają się do kilku obszarów. Po pierwsze, podczas gdy standardowe witryny WWW pełnią głównie funkcje informacyjne – służąc na przykład jako portfolio czy proste strony informacyjne – aplikacje internetowe są par excellence narzędziami umożliwiającymi realizację różnych zaawansowanych operacji, takich jak transakcje bankowe, zakupy czy zarządzanie treścią witryny. Po drugie, z punktu widzenia stosowanych technologii, o ile zwykła witryna zazwyczaj bazuje wyłącznie na statycznym kodzie HTML, arkuszach stylów i ewentualnie prostych skryptach JavaScript, o tyle aplikacja stosuje bardziej zaawansowane języki programowania, wykonujące zadania po stronie serwera (np. PHP, Java, node.js, Python itp.). Często również technologie te integrują się z systemami bazodanowymi różnego autoramentu. Wreszcie, aplikacje internetowe umożliwiają dynamiczną personalizację doświadczenia i danych w zależności od zalogowanego użytkownika, co wprost odróżnia je od statycznych stron WWW [2].

We współczesnym świecie znaczenie aplikacji internetowych jest niewspółmiernie bardziej krytyczne dla funkcjonowania gospodarki cyfrowej, niż miało to miejsce jeszcze kilka lat temu. Coraz więcej firm zaczęło adaptować swoje klasyczne oprogramowanie do realiów internetowych stosując technologie WWW. Z kolei coraz więcej klientów polegać zaczęło na tychże aplikacjach, co naturalnie wymusza szybki i nieustanny ich rozwój. Sektory takie jak finanse, ochrona zdrowia, administracja publiczna czy sprzedaż online są całkowicie uzależnione od dostępności i poprawności działania tych systemów.

Ta powszechność sprawia, że współczesne organizacje utrzymują w swoich infrastrukturach od dziesiątek do nawet setek aplikacji, co znacząco zwiększa powierzchnię ataku. W konsekwencji systemy te stają się pierwszym celem cyberprzestępców. Zapewnienie ich ciągłej dostępności w obliczu ataków mających na celu wyczerpanie zasobów staje się zatem jednym z najważniejszych wyzwań współczesnej inżynierii bezpieczeństwa.

I.2. Charakterystyka ataków DoS

Mając na uwadze charakter niniejszej pracy, skupiono się na charakterystyce ataków DoS, klasyfikacji różnych wektorów i typów ataków jak i omówieniu narzędzi i metod stosowanych do ich przeprowadzenia.

Sztandarowym źródłem wiedzy dotyczącej bezpieczeństwa internetowego są zasoby i publikacje organizacji OWASP (z ang. *Open Web Application Security Project*). Instytucja ta, stanowiąca charytatywną społeczność internetową istniejącą od 2001 roku, wytwarza i nieodpłatnie rozpowszechnia powszechnie uznawane w branży zalecenia dotyczące standardów bezpieczeństwa, w tym listę najkrytyczniejszych zagrożeń dla aplikacji webowych (tzw. *OWASP Top 10*), a także wytwarza narzędzia kluczowe w zakresie testowania bezpieczeństwa aplikacji sieciowych [3]. W swoich publikacjach definiuje również terminologię branżową, w tym między innymi precyzuje definicję ataku odmowy usługi (DoS).

I.2.1. Definicja ataku DoS i jego cele

Zgodnie z literaturą przedmiotu oraz dokumentacją OWASP, atak DoS, czyli Denial of Service, definiuje się jako działania mające na celu zakłócenie dostępu do zasobu sieciowego lub komputerowego (na przykład aplikacji internetowej) dla zwykłych, uprawnionych użytkowników. Charakteryzują się one przeciążeniem ruchu, gdzie atakujący wysyła większą liczbę żądań niż system jest w stanie obsłużyć, wyczerpując zasoby atakowanego hosta takie jak przepustowość, moc obliczeniowa procesora lub pamięć. Dodatkowo, niektóre ataki DoS wykorzystują podatności w systemie, atakując specyficzne słabości oprogramowania lub sprzętu w serwerach, aplikacjach lub urządzeniach sieciowych. [4, 5]

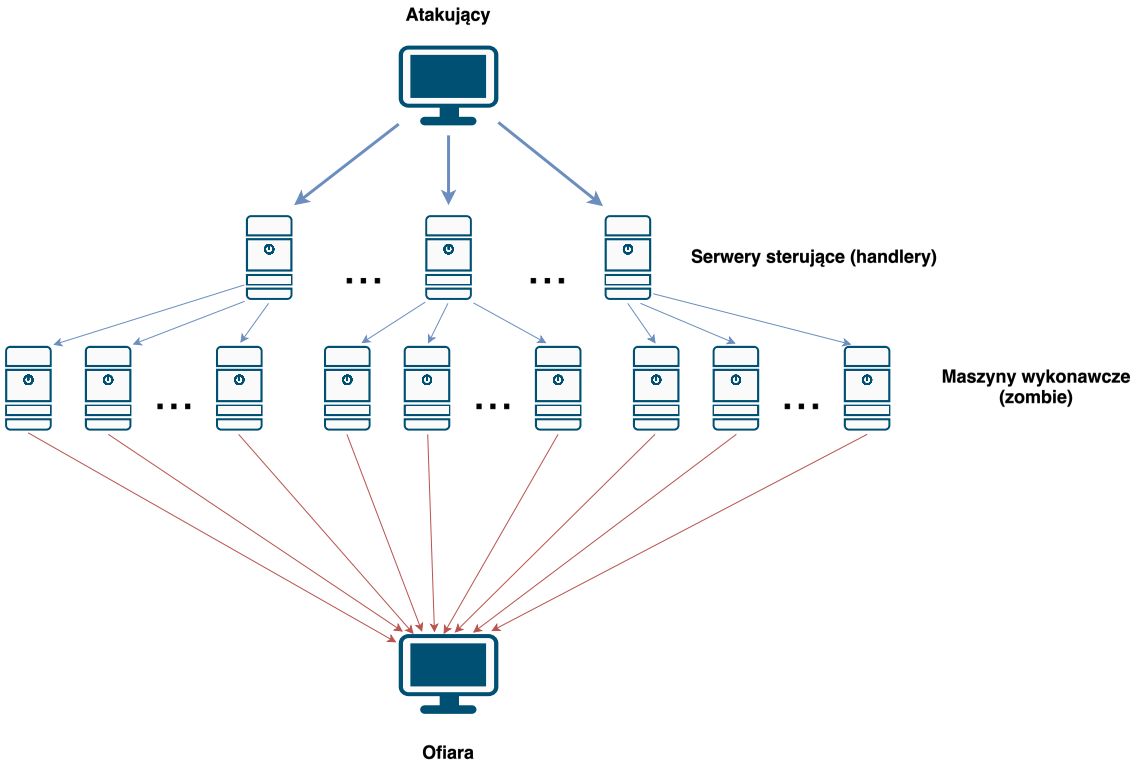
Zasadniczym celem ataków DoS jest naruszenie jednego z filarów triady bezpieczeństwa informacji (z ang. *CIA – Confidentiality, Integrity, Availability*), a mianowicie dostępności. Motywy sprawców bywają różne – od próby szantażu i wyłudzenia okupu, gdzie niedostępność aplikacji/zasobu może powodować olbrzymie straty u ofiary, przez chęć odwrócenia uwagi od właściwego ataku (wymierzonego np. ze strony konkurencji), kończąc na tzw. haktywistach – osobach popełniających ataki w celu wyrażenia politycznego stanowiska lub zwrócenia uwagi na dany problem.

W praktyce ataki DoS wymierzone mogą być w różne zasoby: infrastrukturę sieciową (łącza internetowe), system operacyjny (wyczerpywanie tablicy połączeń), aż po warstwę aplikacji, z zamierzeniem wyczerpania puli połączeń z bazą danych lub cykli procesora niezbędnych do obsłużenia skomplikowanych zapytań. W dobie chmury obliczeniowej pojawiła się również nowa forma zagrożenia określana mianem EDoS (z ang. *Economic Denial of Sustainability*), gdzie celem ataku nie jest całkowite unieruchomienie usługi, lecz wymuszenie na ofierze, korzystającej z elastycznych zasobów chmurowych (z ang. *pay-as-you-go*), poniesienia drastycznie wysokich kosztów operacyjnych na skutek sztucznie generowanego ruchu. [6]

Ze względu na ekonomiczny charakter tego zagrożenia, niebędącego bezpośrednim atakiem na infrastrukturę sprzętową ani aplikację internetową, nie będzie ono przedmiotem dalszych rozważań w niniejszej pracy.

I.2.2. Ataki DDoS i różnice względem DoS

Ewolucja zagrożeń sieciowych doprowadziła do powstania bardziej zaawansowanych, rozproszonych ataków odmowy usługi, znanych jako DDoS (z ang. *Distributed Denial of Service*). W odróżnieniu od klasycznego ataku DoS, w którym źródłem szkodliwego ruchu jest zazwyczaj jeden lub kilka hostów, atak DDoS realizowany jest przy użyciu wielu skoordynowanych urządzeń, często rozproszonych geograficznie. Schemat takiego ataku jest z reguły identyczny i składa się z czterech głównych elementów: atakującego, serwerów sterujących (tzw. handlerów lub kontrolerów), zainfekowanych maszyn wykonawczych zwanych "zombie" lub botami (tworzących tzw. botnet) oraz ofiary.



Rys. 1. Schemat ataku DDoS

(źródło: opracowanie własne)

Zasadnicza różnica w skuteczności między tymi dwoma typami ataków wynika ze skali działania. Podczas gdy atak DoS angażuje ograniczone zasoby, atak DDoS potrafi zmobilizować setki lub nawet tysiące maszyn atakujących jednocześnie. Taka architektura sprawia, że jest on znacznie trudniejszy do odparcia, ponieważ blokowanie pojedynczych adresów IP nie przynosi rezultatu w obliczu zmasowanego ruchu pochodzącego z wielu różnych podsieci. [5]

Szczególne wyzwanie stanowią ataki DDoS realizowane w warstwie aplikacji. W przeciwieństwie do ataków w warstwie sieciowej, które zalewają łącze błędnymi pakietami, ataki aplikacyjne wykorzystują w pełni poprawne zapytania HTTP (z ang. *Hypertext Transfer Protocol*) i HTTPS (z ang. *Hypertext Transfer Protocol Secure*). Z punktu widzenia serwera między pakietem pochodzącym z ataku DDoS a pakietem od legalnego użytkownika nie ma praktycznie żadnej różnicy w strukturze. Sprawia to, że podstawowe mechanizmy obronne oraz standardowe firewalle często okazują się nieskuteczne w ich detekcji, przepuszczając szkodliwy ruch do serwera.

W kontekście rozważań o dostępności usług należy również wspomnieć o zjawisku nieintencjonalnego "ataku", określanego w literaturze mianem nagłego tłumu (z ang. *flash crowd*). Z technicznego punktu widzenia objawia się on nagłym skokiem liczby zapytań HTTP, co czyni go łudząco podobnym do ataku DDoS w warstwie aplikacji. Różnica polega na tym, że ruch ten generowany jest przez legalnych użytkowników, wykonujących np. podobne zapytania. Przykładem takiej sytuacji może być wyprzedaż w sklepie internetowym lub ważne wydarzenie medialne, które przyciąga do aplikacji rzesze zainteresowanych użytkowników w tym samym czasie. Rozróżnienie między atakiem DDoS a zjawiskiem nagłego tłumu jest kluczowe dla systemów obronnych, gdyż omyłkowe zablokowanie legalnego ruchu może przynieść organizacji wymierne straty wizerunkowe i finansowe. [7]

I.2.3. Klasyfikacja ataków DoS i narzędzia ataku

Zrozumienie mechanizmów działania ataków DoS wymaga ich systematyzacji. W literaturze przedmiotu najczęściej stosowanym kryterium podziału jest odniesienie do modelu ISO/OSI (z ang. *ISO Open Systems Interconnection*). Na tej podstawie ataki klasyfikuje się na dwie główne grupy: ataki sieciowe i transportowe (warstwy L3 i L4) oraz ataki w warstwie aplikacji (warstwa L7). Każda z tych kategorii charakteryzuje się odmienną specyfiką, celami oraz wykorzystywanym instrumentarium.

Ataki sieciowe, określane często mianem ataków wolumetrycznych lub transportowych, to najstarsza i najbardziej rozpowszechniona forma ataków DoS. Ich głównym celem jest wyczerpanie przepustowości łącza lub zasobów sprzętowych urządzeń sieciowych (takich, jak firewalle, routery czy load balancery) poprzez zalanie ich ruchem przekraczającym ich możliwości przetwarzania. Działania te opierają się na generowaniu ogromnej liczby pakietów wykorzystując protokoły warstw L3 i L4 – przede wszystkim TCP (z ang. *Transmission Control Protocol*), UDP (z ang. *User Datagram Protocol*) oraz ICMP (z ang, *Internet Control Message Protocol*).

Konstrukcja tych ataków wykorzystuje specyfikę poszczególnych protokołów. W przypadku bezpołączeniowego protokołu UDP, atak polega najczęściej na wysyłaniu datagramów na losowe porty systemu docelowego, co zmusza go do ciągłego sprawdzania aktywności usług i generowania odpowiedzi ICMP o niedostępności portu, marnując tym samym moc obliczeniową. Z kolei w warstwie transportowej ataki często manipulują flagami sterującymi w nagłówku pakietu, nadużywając mechanizmu

nawiązywania połączenia (tzw. *three-way handshake*, specyficzny dla protokołu TCP). Przykładem jest atak TCP SYN Flood, w którym napastnik masowo wysyła pakiety inicjujące z ustawioną flagą SYN, często fałszując przy tym źródłowy adres IP (tzw. *IP Spoofing*). Prowadzi to do wyczerpania tablicy stanów serwera, który rezerwuje pamięć na półotwarte połączenia, oczekując na pakiety finalizujące ACK, które nigdy nie nadchodzą. Często pakiety te są celowo zniekształcone lub nieprawidłowo sfragmentowane, aby dodatkowo utrudnić ich filtrację przez standardowe systemy bezpieczeństwa. [4, 7, 8]

Do realizacji powyżej opisanych scenariuszy ataków wykorzystuje się szeroki wachlarz oprogramowania – od prostych skryptów typu *Proof of Concept*, po zaawansowane narzędzia wykorzystywane w prawdziwych atakach DDoS. Do najpopularniejszych zalicza się: hping3, czyli zaawansowany generator pakietów, który umożliwia precyzyjne konstruowanie nagłówków TCP/IP i wykonywanie ataków pokroju TCP SYN Flood, oraz LOIC/HOIC (z ang. *Low Orbit Ion Cannon/High Orbit Ion Cannon*) – proste w użytku narzędzia zawierające graficzny interfejs użytkownika, umożliwiające przeprowadzenie skutecznych ataków TCP, UDP oraz HTTP Flood w prosty sposób.

Drugą, bardziej wyrafinowaną i zupełnie odmienną grupą ataków typu DoS są ataki w warstwie aplikacji (warstwa 7 modelu OSI). W przeciwieństwie do wyżej opisywanych ataków wolumetrycznych, działania te nie wymagają generowania nasilonego ruchu sieciowego; zamiast tego wykorzystują w pełni poprawne, zgodne ze standardami zapytania protokołów aplikacyjnych, głównie HTTP/HTTPS, jak i również DNS (z ang. *Domain Name System*) czy SIP (z ang. *Session Initiation Protocol*). Istotą tego ataku jest zmuszenie serwera do zaalokowania nieproporcjonalnie dużych zasobów – takich, jak czas procesora, pamięć RAM, połączenia z bazą danych czy gniazda sieciowe – w odpowiedzi na relatywnie niewielką liczbę żądań przychodzących. Ze względu na wykorzystywanie legalnych nagłówków i struktur danych, ruch ten jest bardzo trudny do odróżnienia od aktywności zwykłych użytkowników przez konwencjonalne systemy zaporowe, co w konsekwencji komplikuje również jego filtrowanie i blokowanie.

W literaturze przedmiotu wyróżnia się dwie główne strategie ataku aplikacyjnego. Pierwszą są ataki typu HTTP Flood, realizowane m.in. przez narzędzia takie jak HULK (skrót od *HTTP Unbearable Load King*) czy GoldenEye. HULK, będący w istocie skryptem Python, generuje losowe zapytania z unikalnymi wartościami nagłówków, co pozwala na ominięcie systemów pamięci podręcznej (tzw. *cache*) i wymusza na serwerze każdorazowe, pełne przetworzenie żądania. Z kolei GoldenEye, pierwotnie narzędzie do testów obciążeniowych, próbuje wyczerpać pulę dostępnych wątków serwera poprzez otwarcie wielu równoległych połączeń z wykorzystaniem mechanizmu Keep-Alive (umożliwiającego utrzymanie aktywnej sesji TCP między klientem a serwerem w celu obsługi wielu żądań bez konieczności ponownego

nawiązywania połączenia). Do tego celu wykorzystuje się również komercyjne narzędzia – w tym darmowe Apache JMeter oraz Grafana k6. Drugą, bardziej podstępną strategią są ataki typu Low and Slow, które celują w limity współbieżnych połączeń serwera webowego (np. Apache, Nginx). Sztandarowym przykładem jest tu atak Slowloris, polegający na inicjacji setek połączeń, przy wysyłaniu tylko cząstkowych nagłówków HTTP i utrzymywaniu sesji w nieskończoność poprzez cykliczne przesyłanie minimalnych porcji danych, co uniemożliwia zwolnienie zasobów dla legalnych klientów. Analogiczną technikę, jednakże dla metody POST, stosuje narzędzie *slowhttptest.* Umożliwia ono wykonanie ataku R-U-D-Y (skrót od *R-U-Dead-Yet*) – polega on na deklaracji dużego rozmiaru treści w nagłówku Content-Length, a następnie przesyłanie ciała żądania w ekstremalnie wolnym tempie (np. jeden bajt co kilka sekund), skutecznie blokując aplikację, która oczekuje na kompletne dane. [4, 7, 8]

Rozważając klasyfikację ataków DoS warto również wspomnieć o atakach wielowektorowych, które stanowią syntezę opisanych wcześniej metod. Polegają one na skoordynowanym, równoległym wykorzystaniu różnych technik – na przykład jednoczesnym nasyceniu łącza atakiem wolumetrycznym (L3/L4) w celu odwrócenia uwagi systemów bezpieczeństwa, przy jednoczesnym uderzeniu w warstwę aplikacji (L7). Taka hybrydowa strategia drastycznie utrudnia proces mitygacji, gdyż wymaga jednoczesnej analizy i blokowania zagrożeń na wszystkich warstwach modelu sieciowego.

I.3. Narzędzia i technologie ochrony przed atakami DoS

Współczesna inżynieria bezpieczeństwa sieciowego musi mierzyć się ze skalą, jak i asymetrią konfliktu, w którym atakujący dysponują znaczną przewagą w doborze czasu i metody ataku, podczas gdy obrońcy muszą utrzymywać ciągłą gotowość i odporność infrastruktury na ataki. Skuteczna mitygacja ataków DoS wymaga zatem podejścia wielowarstwowego, łączącego różnorodne technologie detekcji i neutralizacji zagrożeń. Przegląd dostępnych rozwiązań należy rozpocząć od technologii fundamentalnych, stanowiących pierwszą linię obrony w większości organizacji.

I.3.1. Tradycyjne rozwiązania bezpieczeństwa

Historycznie pierwszym i do dziś podstawowym elementem architektury bezpieczeństwa są zapory sieciowe (ang. *firewall*). Ich działanie opiera się na filtrowaniu ruchu wchodzącego i wychodzącego na podstawie zdefiniowanego zestawu reguł i polityk bezpieczeństwa, uwzględniających zazwyczaj adresy IP źródła i celu, numery portów oraz protokoły transportowe. Choć stanowią one niezbędną barierę dla np. nieautoryzowanego dostępu do zasobów, w kontekście ochrony przed atakami DoS ich skuteczność jest ograniczona. Tradycyjne firewalle często nie są w stanie rozróżnić masowego, złośliwego ruchu od legalnego, jeśli ten pierwszy spełnia formalne reguły polityki (np. jest skierowany na dozwolony port 80). Co więcej, w przypadku ataków

wolumetrycznych o dużej skali, same zapory mogą stać się problemem, ulegając awarii na skutek wyczerpania tablicy stanów połączeń.

Uzupełnieniem funkcjonalności zapór sieciowych są systemy IDS (z ang. *Intrusion Detection Systems*). Narzędzia te umożliwiają pasywne monitorowanie ruchu sieciowego w poszukiwaniu nietypowych wzorców lub sygnatur znanych ataków. IDS analizuje przepływ danych i oznacza podejrzane pakiety do dalszej weryfikacji, stanowiąc kluczowy element dla analizy wektora ataku. Należy jednak zaznaczyć, że systemy te działają głównie w trybie detekcji, a nie prewencji, co w przypadku dynamicznie narastających ataków DoS może okazać się niewystarczające do odparcia zagrożenia.

Naturalną ewolucją omówionych wyżej rozwiązań, łączącą cechy zapór sieciowych i systemów detekcji, stała się technologia NGFW (z ang. *Next-Generation Firewall*). Urządzenia te wypełniają lukę między klasycznymi rozwiązaniami filtrującymi a zaawansowaną ochroną aplikacji, oferując znacznie szersze możliwości niż tradycyjne firewalle. Dzięki zintegrowaniu mechanizmów głębokiej inspekcji pakietów oraz funkcji IPS (z ang. *Intrusion Prevention System*), zapory NGFW nie ograniczają się jedynie do pasywnego monitorowania, lecz są w stanie aktywnie blokować wykryte zagrożenia, a wbudowane moduły bezpieczeństwa pozwalają na skuteczną detekcję i mitygację podstawowych ataków typu DoS oraz prostszych prób przeciążenia infrastruktury sieciowej.

W odpowiedzi na specyfikę zagrożeń celujących w warstwę siódmą modelu OSI, standardem stały się zapory aplikacji internetowych (WAF, z ang. *Web Application Firewalls*). Oferują one znacznie bardziej zaawansowaną ochronę niż klasyczne firewalle sieciowe, ponieważ dokonują bardziej precyzyjnej inspekcji treści żądań HTTP/HTTPS. Pozwala to na analizę wzorców ruchu przychodzącego oraz wykrywanie anomalii, które mogą wskazywać na próbę ataku aplikacyjnego, nawet jeśli pochodzi on z pozornie zaufanego źródła. W systemach WAF zaimplementowane są również mechanizmy obronne oparte m.in. na ograniczaniu szybkości żądań, co pozwala na blokowanie nadmiernej liczby zapytań generowanych przez pojedynczy adres IP lub sesję w krótkim czasie. Jest to kluczowe w walce z atakami typu HTTP Flood czy Brute Force, a także w ochronie przed zagrożeniami skategoryzowanymi w ramach listy OWASP Top 10, które wykorzystują luki w samej logice aplikacji (np. ataki SQL Injection, XSS, Path Traversal i inne). Pomimo wysokiej skuteczności, zdarza się, że nawet systemy WAF (z reguły te błędnie skonfigurowane) napotykają trudności w odróżnianiu wyrafinowanych botów od legalnych użytkowników, zwłaszcza gdy atakujący imitują zachowanie ludzkie (np. w atakach typu Low and Slow).

I.3.2. Przegląd zaawansowanych rozwiązań ochrony przed DoS

Ograniczenia przepustowości i wydajności urządzeń stosowanych lokalnie sprawiły, że w walce z masowymi atakami DoS kluczową rolę zaczęły odgrywać rozwiązania oparte na chmurze obliczeniowej. Usługi te, działające często w modelu ochrony przed atakami DDoS w ramach subskrypcji, pozwalają na eliminację złośliwego ruchu o skali niemożliwej do obsłużenia przez pojedynczą serwerownię o niewielkich zasobach. Wśród wiodących dostawców tych technologii wyróżnić można kilka kluczowych podmiotów, z których każdy stosuje odmienną architekturę i strategię obronną.

Jednym z liderów w dziedzinie ochrony rozproszonej jest Cloudflare, którego model działania opiera się na wykorzystaniu globalnej sieci Anycast. Technologia ta pozwala na rozgłaszanie tego samego adresu IP z wielu lokalizacji geograficznych jednocześnie, co skutkuje automatycznym rozproszeniem ataku wolumetrycznego na krawędzi sieci, zanim dotrze on do infrastruktury ofiary. Rozwiązanie to charakteryzuje się ogromną pojemnością mitygacji, co pozwala na neutralizację nawet największych ataków *DoS* w warstwie 3 i 4. [9]

Odmienne podejście prezentuje firma Akamai w swojej usłudze Prolexic, która koncentruje się na zapewnieniu najwyższej dostępności dla infrastruktury krytycznej i przedsiębiorstw. Akamai wykorzystuje jedną z największych na świecie sieci dostarczania treści (CDN, z ang. *Content Delivery Network*), obejmującą ponad 233 000 serwerów w ponad 130 krajach. Taka skala pozwala na mitygację ataku blisko jego źródła. [10]

W kontekście dynamicznie rozwijających się środowisk chmurowych, istotną rolę odgrywa usługa AWS Shield, będąca natywnym rozwiązaniem platformy Amazon Web Services. Jest ona dostępna jest w dwóch wariantach. Wersja Standard, bezpłatna dla wszystkich klientów AWS, zapewnia podstawową ochronę warstwy sieciowej (L3/L4), chroniąc zasoby przed typowymi atakami wolumetrycznymi. Z kolei wariant Advanced oferuje zaawansowaną ochronę warstwy aplikacji, integrując się z usługą AWS WAF oraz zapewniając wsparcie dedykowanego zespołu reagowania. Unikalną cechą AWS Shield Advanced jest mechanizm detekcji oparty na "stanie zdrowia" aplikacji, co pozwala na precyzyjne odróżnienie ataku od legalnego wzrostu ruchu. [11]

Istnieją również rozwiązania hybrydowe, np. oferowane przez firmę Radware. Jej flagowy produkt, DefensePro X, to dedykowane urządzenie (lub wirtualna maszyna), które implementuje zaawansowane algorytmy analizy behawioralnej. W przeciwieństwie do prostych metod opartych na progach, silnik Radware automatycznie uczy się wzorców normalnego ruchu i w czasie rzeczywistym generuje sygnatury blokujące dla nowo wykrytych zagrożeń. Pozwala to na skuteczną mitygację nie tylko znanych ataków wolumetrycznych i aplikacyjnych, ale również zagrożeń typu zero-day, które nie posiadają jeszcze zdefiniowanych sygnatur w publicznych bazach zagrożeń. [12]

I.3.3. Strategie obrony wielowarstwowej

Poleganie na pojedynczym mechanizmie zabezpieczającym – nawet tak zaawansowanym jak WAF – zawsze obarczone będzie wysokim ryzykiem błędu, jeżeli będzie to jedyna linia obrony. Dlatego też do skutecznej mitygacji ataków DoS zaimplementować należy strategię obrony wielowarstwowej. Podejście to zakłada nakładanie się na siebie różnych technologii i procedur, które wzajemnie się uzupełniają, tworząc szczelny system ochronny.

Fundamentem tego podejścia jest redundancja infrastruktury, realizowana poprzez architekturę wysokiej dostępności, co umożliwia dynamiczne przekierowanie ruchu do zapasowych centrów danych w przypadku przeciążenia lokalizacji pierwotnej. Równie istotnym elementem jest skalowalność zasobów, osiągana dzięki wykorzystaniu chmury obliczeniowej zdolnej do automatycznej alokacji mocy (tzw. *auto-scaling*) w odpowiedzi na nagłe skoki ruchu, charakterystyczne dla ataków wolumetrycznych. Proces ten wspierany jest przez mechanizmy równoważenia obciążenia (tzw. *load balancing*), które dywersyfikują żądania sieciowe pomiędzy wiele serwerów, zapobiegając nadużycia pojedynczych jednostek. Warstwę prewencyjną dopełnia zaawansowana analiza ruchu, przechodząca od pasywnego monitorowania do aktywnej detekcji behawioralnej, uczącej się wzorców normalnego działania w celu identyfikacji anomalii. Całość strategii spina integracja z wyspecjalizowanymi usługami w modelu hybrydowym, łączącymi precyzję lokalnych systemów WAF/IDS z potężną przepustowością chmurowych rozwiązań, które są w stanie filtrować masowy ruch przed dotarciem do sieci organizacji.

Rozdział II. Analiza funkcji oferowanych przez urządzenie F5 BIG-IP

II.1. Firma F5 Inc. – profil działalności i oferowane rozwiązania

Rozważania na temat konkretnych rozwiązań technologicznych należy poprzedzić analizą profilu ich producenta, gdyż przyjęta filozofia projektowa bezpośrednio determinuje architekturę systemów bezpieczeństwa. F5, Inc. (dawniej F5 Networks) to amerykańskie przedsiębiorstwo technologiczne z siedzibą w Seattle, które od momentu powstania w 1996 roku ewoluowało z producenta prostych rozwiązań do równoważenia obciążenia (tj. load balancery) w globalnego lidera rynku zintegrowanych platform dostarczania aplikacji, systemów WAF oraz bezpieczeństwa aplikacji wielochmurowych.

Historycznie, działalność F5 koncentrowała się na optymalizacji dostępności serwisów internetowych poprzez inteligentne zarządzanie ruchem sieciowym. Jednakże dynamiczny wzrost zagrożeń, z naciskiem na ataki w warstwie siódmej modelu ISO/OSI wymusił zmianę paradygmatu – z czystej wydajności na zintegrowane bezpieczeństwo. Współczesne portfolio firmy opiera się na koncepcji, w której urządzenie sieciowe nie jest jedynie pasywnym przekaźnikiem pakietów, lecz pełni rolę Full Proxy. Oznacza to, że system F5 staje się pośrednikiem w każdej sesji TCP/IP, terminując połączenie od klienta i nawiązując nowe z serwerem docelowym. Taka architektura pozwala na pełną inspekcję, modyfikację i filtrowanie ruchu w obu kierunkach, co jest kluczowe dla skutecznej detekcji zaawansowanych ataków DoS i DDoS oraz prób wykorzystywania luk w aplikacjach webowych. [13]

Analizując pozycję rynkową firmy F5 Networks, należy zwrócić uwagę na dynamikę zmian w sektorze bezpieczeństwa aplikacji. W raporcie *Gartner Magic Quadrant for Web Application Firewalls* z 2017 roku firma F5 była klasyfikowana w ścisłym gronie liderów, co potwierdzało jej dominację w erze rozwiązań sprzętowych i wirtualnych [14–16]. W kolejnych latach, wraz z ewolucją rynku w stronę modeli chmurowych i zmianą kategorii na *Web Application and API Protection* (WAAP), nowsze zestawienia (np. z lat 2021–2022) zaczęły premiować dostawców usług SaaS, takich jak Akamai czy Cloudflare, przesuwając F5 do roli pretendenta (z ang. *Challenger*) w tym specyficznym ujęciu [17]. Należy jednak podkreślić, że rankingi te koncentrują się na trendach chmurowych i nie oddają w pełni potencjału technologicznego platformy BIG-IP w środowiskach hybrydowych oraz on-premise. Mimo zmian w zestawieniach analitycznych, F5 pozostaje niekwestionowanym standardem w infrastrukturze krytycznej największych przedsiębiorstw i instytucji finansowych, oferując poziom konfigurowalności i wydajności, który często pozostaje nieosiągalny dla czysto chmurowej konkurencji



Rys. 2. Wizualizacja raportu Gartner Magic Quadrant for WAF (2017)

(źródło: https://avleonov.com/2017/08/16/whats-new-in-gartner-waf-magic-quadrant-2017/)



Rys. 3. Wizualizacja raportu Gartner Magic Quadrant for WAAP (2021)

(źródło: https://www.akamai.com/blog/news/akamai-named-a-gartner-magic-quadrant-leader-for-web-application-and-api-protection)

Wraz z reorientacją strategii w stronę cyberbezpieczeństwa, F5 ugruntowało swoją dominację również w sektorze ochrony aplikacji webowych. W raporcie IDC MarketScape: Worldwide Web Application and API Protection Enterprise Platforms 2024, F5 zostało uznane za lidera [18].Takie wyróżnienia świadczą o tym, że opisywane w niniejszej pracy narzędzia firmy F5 nie są niszowymi rozwiązaniami, lecz stanowią de facto standard przemysłowy, wykorzystywany przez największe organizacje na świecie do ochrony infrastruktury krytycznej.

W ofercie F5 można wyróżnić kilka najważniejszych produktów związanych z dostępnością oraz bezpieczeństwem aplikacji internetowych [19]:

- F5 BIG-IP: Flagowa platforma producenta, łącząca funkcje zarządzania ruchem i bezpieczeństwa. Jest to rozwiązanie modułowe, działające pod kontrolą systemu operacyjnego TMOS (skrót od *Traffic Management Operating System*), które może być wdrażane zarówno w formie dedykowanych urządzeń sprzętowych, jak i wirtualnych instancji (Virtual Editions).
- F5 NGINX: Po przejęciu w 2019 roku firmy NGINX stojącej za najpopularniejszym serwerem WWW na świecie, F5 dodało technologie NGINX do swojego portfolio. Jest to rozwiązanie do zarządzania ruchem sieciowym, które łączy w sobie funkcje serwera WWW, reverse proxy, load balancera oraz bramy API – stworzone głównie dla nowoczesnych mikroserwisów i platform kontenerowych (Kubernetes).
- F5 Distributed Cloud Services: Jest to platforma typu SaaS (z ang. *Software as a Service*), która umożliwia ochronę aplikacji rozproszonych pomiędzy różnymi chmurami publicznymi (AWS, Azure, Google Cloud) oraz lokalnymi centrami danych (tzw. on-premise), zapewniając spójną politykę bezpieczeństwa niezależnie od lokalizacji zasobów.

Z perspektywy niniejszej pracy najistotniejszym rozwiązaniem z produktów F5 jest platforma BIG-IP, która dzięki swojej programowalności oraz dedykowanym modułom bezpieczeństwa, stanowi najlepsze rozwiązanie dla ochrony usług sieciowych przed atakami DoS.

II.2. Charakterystyka i architektura platformy F5 BIG-IP

Zrozumienie mechanizmów ochrony przed atakami DoS, które są przedmiotem badań w dalszej części pracy, wymaga szczegółowej analizy architektury platformy F5 BIG-IP, jego systemu operacyjnego oraz dostępnych modeli wdrożeniowych.

Kluczową cechą wyróżniającą BIG-IP na tle tradycyjnych routerów i firewalli jest architektura Full Proxy, odmienna od tradycyjnych rozwiązań przesyłających pakiety. Dla każdej sesji przychodzącej BIG-IP tworzy dwa niezależne połączenia TCP: jedno od strony klienta do urządzenia oraz drugie od urządzenia do serwera docelowego. Taka separacja pozwala na pełną inspekcję zawartości pakietów (np. w celu analizy

przed znanymi wektorami ataków) oraz, co istotniejsze w kontekście bezpieczeństwa i dostępności aplikacji, buforowanie ruchu. Dzięki temu ataki wymierzone w warstwę sieciową i transportową mogą być neutralizowane bezpośrednio na urządzeniu brzegowym, nigdy nie docierając do chronionych przez nie serwerów aplikacyjnych.

Sercem platformy jest specjalny system operacyjny TMOS (skrót od: *Traffic Management Operating System*) oparty o jądro Linux. Zapewnia on pełną widoczność, elastyczność i kontrolę nad wszystkimi usługami BIG-IP, a także aktualizacje komponentów systemu, jak np. sygnatury ataków. Zarządzanie systemem, a tym samym ustawieniami platformy BIG-IP możliwe jest na kilka sposobów: bezpośrednio przez terminal urządzenia, zdalnie z wykorzystaniem protokołu SSH oraz za pomocą dedykowanego interfejsu webowego, udostępnianego automatycznie pod adresem IP interfejsu zarządzającego (*mgmt*). Dzięki w pełni konfigurowalnym panelom wizualizacyjnym (tzw. *dashboard*), systemom powiadamiania o podejrzanych aktywnościach oraz możliwościom raportowania, TMOS umożliwia także bezpośredni i dogłębny wgląd w pracę systemu oraz przetwarzany przez urządzenie ruch sieciowy.

Z perspektywy wdrożeniowej, rozwiązanie F5 BIG-IP oferuje kilka elastycznych opcji, w zależności od posiadanego środowiska i infrastruktury. Pierwszą z opcji jest rozwiązanie sprzętowe, będące dedykowanym dla systemu TMOS urządzeniem (z serii iSeries, rSeries lub Viprion) gotowym do instalacji w posiadanej infrastrukturze on-premise. Ich unikalną cechą jest wykorzystanie układów FPGA (z ang. *Field-programmable gate array*), specjalnie zaprojektowanych w celu maksymalizacji wydajności. Pozwalają one na sprzętowe przetwarzanie pakietów jeszcze przed dotarciem do głównego procesora. Dzięki temu najczęstsze ataki sieciowe mogą być mitygowane z wydajnością rzędu setek milionów pakietów na sekundę, nie obciążając jednostki centralnej odpowiedzialnej za analizę warstwy aplikacji.



Rys. 4. Urządzenie F5 BIG-IP, model r10900

(źródło: https://wtit.com/f5-products/f5-big-ip-r10600-r10800-r10900-hardware-datasheet/)

Kolejnym, popularnym modelem wdrożeniowym platformy BIG-IP jest edycja wirtualna (VE, z ang. *Virtual editions*), czyli pełnoprawna wersja systemu TMOS gotowa do instalacji w środowiskach zwirtualizowanych, takich, jak VMware, Hyper-V czy QEMU. Pomimo braku akceleracji sprzętowej, spowodowanej brakiem dedykowanych układów FPGA, ta wersja zachowuje pełną funkcjonalność platformy, dodatkowo umożliwiając łatwą aktualizację o większą ilość pamięci operacyjnej lub

przestrzeni dyskowej. Czyni to wersję wirtualną idealnym wyborem dla zwirtualizowanych infrastruktur aplikacyjnych oraz dla środowisk laboratoryjnych (z możliwością wypróbowania środowiska BIG-IP VE przez 30 dni w ramach subskrypcji testowej).

Ostatnią możliwością wdrożenia omawianego rozwiązania jest wersja chmurowa – BIG-IP VE może być uruchamiane bezpośrednio w popularnych chmurach publicznych (jak AWS, Google Cloud Platform czy Microsoft Azure). To eliminuje konieczność posiadania drogiej i zasobożernej infrastruktury lokalnie, zamiast tego wdrażając ją w całości w środowisku *cloud*. Czyni to też omawianą wersję idealnym rozwiązaniem dla wdrażania modelu hybrydowego, łączącego zalety infrastruktury on-premise i chmurowej, gdzie te same polityki bezpieczeństwa mogą być stosowane w obu przypadkach.

Dopełnieniem ekosystemu BIG-IP jest *BIG-IQ Centralized Management*, będące narzędziem do centralnego zarządzania, orkiestracji oraz monitorowania wszystkich urządzeń i instancji wirtualnych F5 w organizacji, co, prócz ułatwienia zarządzania nimi, jest kluczowe dla utrzymania spójności polityk w rozproszonych środowiskach. [19]

II.3. Moduły systemu BIG-IP dedykowane ochronie przed atakami DoS

Architektura bezpieczeństwa platformy F5 BIG-IP opiera się na modułowości, co pozwala na precyzyjne nakładanie kolejnych warstw ochrony w zależności od potrzeb. W ramach projektu ochrony przed atakami DoS kluczowe znaczenie mają trzy komponenty: moduł ASM (skrót od *Application Security Manager*), technologie iRules oraz moduł AFM (skrót od *Advanced Firewall Manager*), których połączenie tworzy kompleksowy system mitygacji ataków DoS zarówno w warstwie aplikacji, jak i sieci.

Centralnym punktem ochrony warstwy siódmej (L7) jest moduł Advanced WAF, znany również jako Application Security Manager (w skrócie ASM). Jego głównym zadaniem jest analiza zapytań HTTP/HTTPS i ochrona przed atakami wymierzonymi w logikę aplikacji, np. tymi z zestawienia *OWASP Top 10* (jak XSS czy SQL Injection). W kontekście ataków odmowy usługi, ASM oferuje zaawansowane mechanizmy, takie jak Behavioral DoS, który wykorzystuje algorytmy uczenia maszynowego do budowania dynamicznego profilu normalnego ruchu. Pozwala to na wykrywanie anomalii, które z perspektywy sieciowej wydają się legalne, ale mają na celu wyczerpanie zasobów serwera (np. ataki Low and Slow). Moduł ten wspiera również funkcję Bot Defense, która poprzez weryfikację przeglądarki (np. testy JavaScript) odcina zautomatyzowane boty i crawlery, zanim zdołają one obciążyć aplikację.

Niemniej jednak, nawet najlepiej skonfigurowane polityki bezpieczeństwa i standardowe mechanizmy ASM mogą okazać się niewystarczające w obliczu niestandardowych ataków DoS. W takich sytuacjach niezbędnym dopełnieniem staje się technologia iRules, działająca w ramach modułu LTM – programowalny interfejs oparty

na języku Tcl, pozwalający na tworzenie autorskich reguł przetwarzania ruchu. iRules daje administratorowi możliwość granularnego i bardzo szczegółowego manipulowania nagłówkami i treścią pakietów. Taka funkcjonalność może okazać się nieoceniona w przypadku specyficznych, nowo odkrytych zagrożeń. Należy jednak podkreślić, że narzędzie to posiada istotne wady: niewłaściwie zoptymalizowany kod może drastycznie zwiększyć obciążenie procesora urządzenia, a błędy w logice skryptu mogą doprowadzić do całkowitego zepsucia konfiguracji połączenia z aplikacją, jak i zerwania z nią legalnych połączeń.

Mimo wysokiej skuteczności powyższych rozwiązań, analiza warstwy aplikacyjnej wciąż pozostaje procesem kosztownym obliczeniowo. Aby zapewnić pełną wydajność i ochronę zarówno urządzenia, jak i aplikacji, niezbędne jest zastosowanie modułu Advanced Firewall Manager (AFM) jako fundamentu całego projektu zabezpieczenia przeciwko atakom DoS. AFM specjalizuje się w mitygacji masowych ataków wolumetrycznych w warstwach L3 i L4 (np. UDP Flood czy TCP SYN Flood), obsługując dziesiątki różnych wektorów zagrożeń sieciowych. Kluczową cechą jest tutaj kolejność przetwarzania pakietów przychodzących do BIG-IP: AFM działa jako pierwszy filtr, odcinając „szum" sieciowy i ataki wolumetryczne, dzięki czemu moduły wyższych warstw (jak ASM) otrzymują do analizy wyłącznie oczyszczony ruch. Funkcja Device DoS w module AFM dba dodatkowo o to, aby samo urządzenie BIG-IP nie uległo przeciążeniu, co w połączeniu z pozostałymi komponentami tworzy wielowarstwową, odporną na ataki DoS infrastrukturę.

Pozostałe moduły systemu BIG-IP, choć nie są dedykowane stricte ochronie przed atakami DoS, również są warte odnotowania w kontekście systemu bezpieczeństwa zdolnego do ochrony przed współczesnymi atakami na aplikację. Podstawowym modułem BIG-IP, będącym niejako fundamentem działania całego systemu, jest wcześniej wspomniany Local Traffic Manager (w skrócie LTM) – działający w trybie *full-proxy*, to on odpowiada za terminację ruchu SSL/TLS, co jest niezbędne do dalszej jego analizy np. przez moduł ASM. Wartym wspomnienia jest również moduł Access Policy Manager (w skrócie APM), umożliwiający wdrożenie polityk uwierzytelniania użytkowników jeszcze przed dopuszczeniem ich do samej aplikacji, co skutecznie zabezpiecza ją przed nieuprawnionym dostępem, oraz eliminuje anonimowe ataki wolumetryczne. Uzupełnieniem tego ekosystemu jest moduł DNS (dawniej GTM, *Global Traffic Manager*), który zabezpiecza infrastrukturę rozwiązywania nazw przed atakami typu DNS Flood zapewniając, że usługi pozostają widoczne dla globalnej sieci Internet.

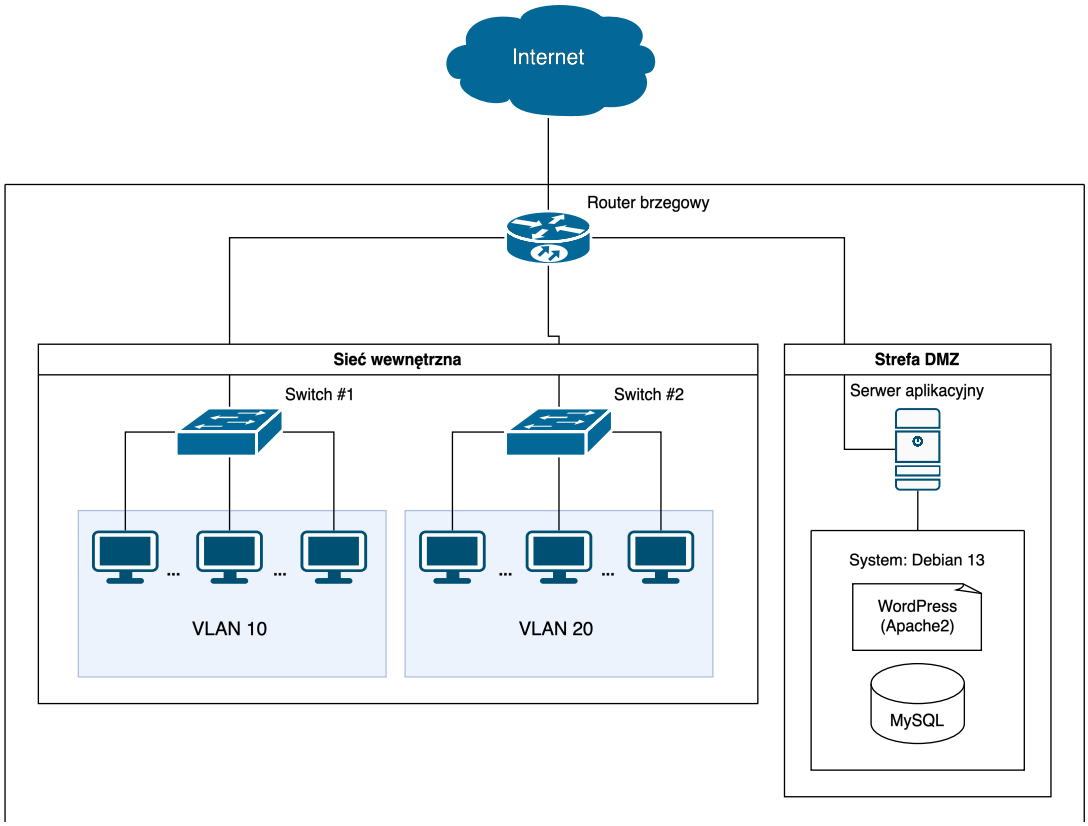
Rozdział III. Opracowanie projektu systemu ochrony aplikacji internetowej

III.1. Opis dotychczasowej infrastruktury

Punktem wyjścia do prac projektowych w ramach niniejszej pracy jest analiza środowiska teleinformatycznego przedsiębiorstwa, dla którego opracowywano projekt zabezpieczeń przed atakami DoS. Kluczowym zasobem firmy, wymagającym szczególnej ochrony ze względu na krytyczność dla procesów biznesowych, jest portal klienta oparty na systemie zarządzania treścią WordPress. Aplikacja ta służy do komunikacji z kontrahentami, udostępniania dokumentacji technicznej oraz obsługi zgłoszeń serwisowych. Niedostępność tego systemu generuje dla organizacji wymierne straty finansowe oraz wizerunkowe.

Infrastruktura sieciowa przedsiębiorstwa jest podzielona na strefy bezpieczeństwa. Ruch internetowy dociera do styku sieci poprzez router brzegowy, którego zadaniem jest segmentacja sieci lokalnej (LAN) na dedykowane wirtualne sieci lokalne (VLAN), przeznaczone dla pracowników.

Serwer aplikacyjny, będący przedmiotem ochrony, umieszczony jest w wydzielonej strefie zdemilitaryzowanej (DMZ). Jest to maszyna wirtualna działająca pod kontrolą systemu operacyjnego Debian w wersji 13, na której uruchomiono w ramach kontenerów Docker serwer WWW Apache2 oraz bazę danych MySQL.



Rys. 5. Schemat logiczny dotychczasowej infrastruktury sieciowej firmy

(źródło: opracowanie własne)

Kluczowym problemem obecnej infrastruktury teleinformatycznej jest brak dedykowanej zapory sieciowej oraz jakichkolwiek urządzeń klasy IDS/IPS na styku sieci. Oznacza to brak jakiejkolwiek ochrony przed atakami wolumetrycznymi oraz brak inspekcji warstwy aplikacji, w celu wykrycia ataków typu HTTP Flood czy Low and Slow.

Warto zaznaczyć, że sama aplikacja WordPress jest regularnie aktualizowana i zabezpieczona przed standardowymi wektorami ataku, takimi jak SQL Injection czy Cross-Site Scripting (XSS), za pomocą wtyczek bezpieczeństwa oraz poprawnie zaimplementowanych mechanizmów walidacji danych wejściowych. W związku z tym, projektowany system ochrony ma skupiać się wyłącznie na zapewnieniu dostępności i mitygacji ataków typu DoS/DDoS, traktując pozostałe zagrożenia jako mitygowane na innym poziomie.

III.2. Cele i założenia projektowe

Jako główny cel realizowanego projektu określono zabezpieczenie krytycznej dla firmy aplikacji WordPress przed atakami DoS i DDoS oraz zapewnienie jej ciągłości działania. W tym celu założono zaprojektowanie i wdrożenie systemu ochrony warstwy aplikacji oraz sieci przed atakami DoS/DDoS, który spełni wszystkie wymagania firmy. Projekt zakłada wprowadzenie urządzenia F5 BIG-IP jako pośrednika w komunikacji, co ma na celu odciążenie serwera końcowego z zadań związanych z bezpieczeństwem.

III.3. Wymagania funkcjonalne

Analiza przyjętych celów projektowych oraz zagrożeń z zakresu ataków odmowy usługi pozwoliła na zdefiniowanie zestawu kluczowych funkcjonalności, które wdrażane rozwiązanie musi realizować. System ochrony musi zapewniać:

- działanie w architekturze Full Proxy, gwarantujące pełną separację logiczną między klientem a chronionym serwerem backendowym,
- automatyczną detekcję i mitygację ataków wolumetrycznych w warstwie sieciowej i transportowej (L3/L4), w tym wektorów takich jak TCP SYN Flood, UDP Flood oraz ICMP Flood,
- wykrywanie i przerywanie ataków w warstwie aplikacji (L7) typu HTTP Flood oraz Low and Slow na podstawie analizy behawioralnej oraz monitorowania wskaźników liczby żądań na sekundę (TPS/RPS),
- obsługę terminacji ruchu szyfrowanego w celu umożliwienia głębokiej inspekcji treści pakietów przed ich przekazaniem do serwera aplikacji,
- weryfikację tożsamości klienta za pomocą mechanizmów Challenge-Response (wstrzykiwanie kodu JavaScript, weryfikacja CAPTCHA) w celu eliminacji ruchu generowanego przez automaty (boty),
- zapewnienie szczegółowego raportowania incydentów w czasie rzeczywistym.

III.4. Wymagania niefunkcjonalne

Uzupełnieniem specyfikacji funkcjonalnej jest zestaw wymagań niefunkcjonalnych, określających parametry pracy systemu oraz jego wpływ na otoczenie sieciowe. Projektowane rozwiązanie F5 BIG-IP musi spełniać następujące kryteria:

- system musi być zaprojektowany w taki sposób, aby był dostępny nieprzerwanie, a w przypadku awarii głównej instancji przetwarzającej ruch, możliwe było natychmiastowe i automatyczne przełączenie na instancję zapasową lub przywrócenie usługi w akceptowalnym czasie,
- mechanizmy ochronne muszą być skonfigurowane w sposób precyzyjny, aby nie blokować ruchu generowanego przez legalnych użytkowników, nawet w okresach wzmożonego obciążenia serwisu,
- architektura rozwiązania powinna umożliwiać łatwą modyfikację i dodawanie nowych polityk bezpieczeństwa (np. sygnatur ataków) bez konieczności przerywania działania usługi,
- system musi zapewniać możliwość konfiguracji poprzez interfejs WWW oraz przez protokół SSH,
- dostęp do panelu administracyjnego urządzenia musi być odseparowany od ruchu produkcyjnego i zabezpieczony protokołami szyfrowanymi.

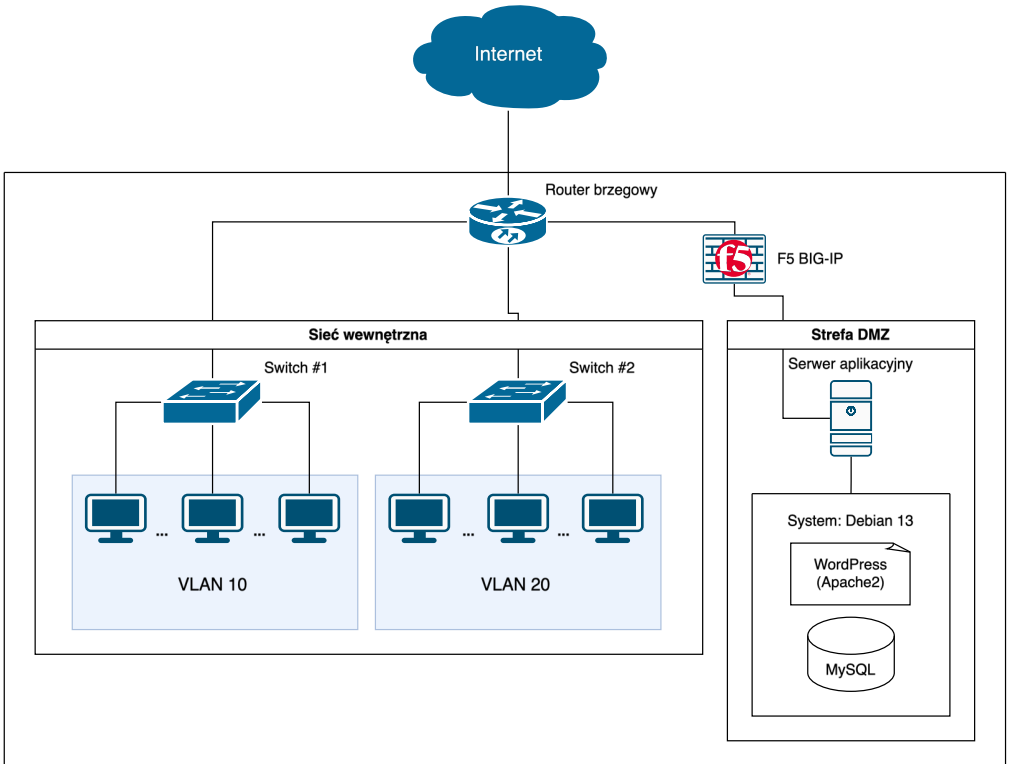
III.5. Projekt systemu ochrony

Mając określone główne cele przedsięwzięcia, wymagania funkcjonalne oraz niefunkcjonalne, przystąpiono do opracowania projektu ochrony aplikacji internetowej. Zakłada on wykorzystanie wcześniej omawianego rozwiązania BIG-IP od firmy F5, w wersji zwirtualizowanej – umożliwi to stosunkowo łatwe zweryfikowanie działania systemu w środowisku testowym, jak i wdrożenie go w dalszej części do infrastruktury produkcyjnej. Umożliwi to również łatwiejszy i tańszy dobór parametrów systemu (jak pamięć RAM, przestrzeń dyskowa lub procesor), w zależności od potrzeb i skali użytkowania aplikacji. Do projektu użyto wirtualizatora VMware Workstation – również, z uwagi na łatwe wdrożenie i testowanie oraz możliwość ewentualnego przeniesienia zarówno samego rozwiązania, jak i całej infrastruktury, do środowiska VMware ESXi/vSphere.

W celu spełnienia wymagań projektowych, oparto wytwarzane rozwiązanie o trzy kluczowe technologie dostępne w ramach platformy BIG-IP: po pierwsze, moduł ASM (*Application Security Manager*), który zapewni ochronę aplikacji internetowej w warstwie L7 (aplikacyjnej), mitygując ataki takie jak HTTP Flood czy Low and Slow. Następnym ważnym modułem jest LTM (*Local Traffic Manager*), odpowiedzialny za monitorowanie pracy serwera, terminację ruchu SSL/TLS i wdrożenie wszystkich projektowanych polityk, oraz technologia skryptów iRules, zawarta w ramach tego modułu – kluczowa dla konstruowania niestandardowych reguł przetwarzania oraz mitygowania nowych, niezdefiniowanych dotychczas podatności, w tym ataków DoS.

Ostatnim, niemniej ważnym elementem rozwiązania, jest moduł AFM (*Advanced Firewall Manager*). Odpowiednio skonfigurowany, spełni on wymagania dotyczące wykrywania oraz eliminowania zagrożeń na warstwie sieciowej i transportowej (L3 oraz L4), a także ochroni samo urządzenie F5 BIG-IP przed potencjalnym atakiem odmowy usługi.

Określono również schemat wdrożenia rozwiązania do dotychczasowej infrastruktury firmy – ponieważ głównym celem jest ochrona aplikacji internetowej znajdującej się w strefie DMZ, maszyna wirtualna z BIG-IP zostanie wdrożona bezpośrednio pomiędzy serwerem obsługującym aplikację, a routerem brzegowym, dzięki czemu aplikacja będzie skutecznie chroniona zarówno spoza sieci korporacyjnej, jak i wewnątrz niej.



Rys. 6. Schemat logiczny infrastruktury firmy po wdrożeniu rozwiązania BIG-IP

(źródło: opracowanie własne)

Przewiduje się implementację rozwiązania w trzech krokach: pierwszy z nich to instalacja maszyny wirtualnej platformy F5 BIG-IP VE w środowisku VMware, oraz konfiguracja niezbędnych ustawień, a także przyłączenie docelowej aplikacji do środowiska przy pomocy modułu LTM. Następnie, konfiguracja i wdrożenie odpowiedniej polityki ochrony przed atakami DoS przy pomocy modułów ASM i AFM oraz technologii iRules. Finalnie, przetestowanie skuteczności rozwiązania poprzez przeprowadzenie testowych ataków DoS na warstwy sieciowe L3/L4 i L7 – zarówno bezpośrednio atakując serwer aplikacji (symulując sytuację sprzed wdrożenia rozwiązania), jak i podając za cel wystawiony przez BIG-IP adres IP wskazujący na aplikację (chronioną).

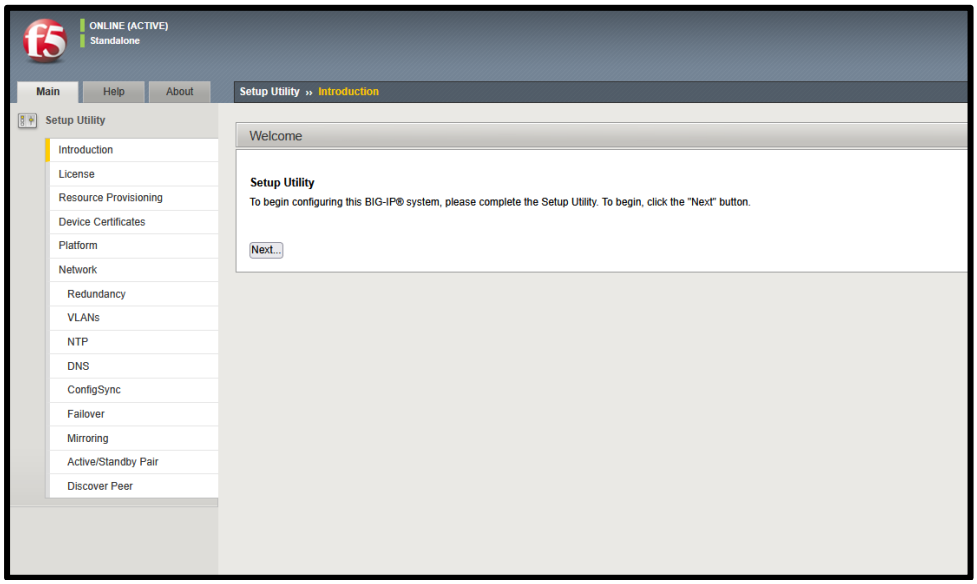
Rozdział IV. Wdrożenie i konfiguracja systemu ochrony

IV.1. Wstępna konfiguracja maszyny wirtualnej i BIG-IP

Pierwszym krokiem w ramach wdrożenia opisywanego w niniejszej pracy systemu ochrony, jest instalacja wirtualizatora VMware, pozyskanie najnowszego obrazu maszyny wirtualnej BIG-IP VE w formacie *.ova* ze strony producenta oraz zaimportowanie jej do narzędzia wirtualizującego. Podczas tego procesu możliwe jest do wybrania kilka wersji maszyny BIG-IP, różniących się ilością pamięci RAM oraz wirtualnych procesorów – ważnym jest, aby dobrać te parametry zgodnie ze specyfikacją sprzętu, który służyć będzie jako host dla wirtualnego środowiska – tak, aby uzyskać jak najwyższą wydajność, bez ryzyka przeciążenia bazowego systemu.

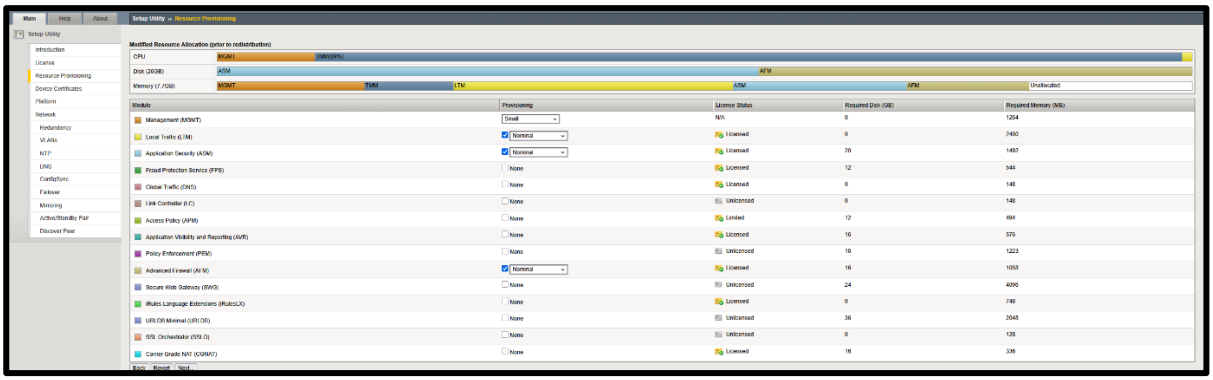
Po przejściu procesu wstępnego logowania oraz konfiguracji interfejsu administracyjnego przy pomocy konsolowego narzędzia *config*, należy zalogować się do interfejsu WWW systemu BIG-IP – to z tego poziomu konfigurowane będą dalsze ustawienia, jak i przygotowane zostaną dalsze rozwiązania.

Interfejs WWW udostępniany jest pod adresem F5 w sieci *management*, wcześniej skonfigurowanym poprzez terminal systemowy – przy jego pierwszym uruchomieniu i zalogowaniu użytkownika powita kreator konfiguracyjny [Rys. 6], w którym najważniejszymi parametrami do skonfigurowania są: licencja, aktywowane moduły (w tym przypadku: LTM, ASM i AFM) [Rys. 7] oraz sieć. W konfiguratorze należy także nadać instancji BIG-IP adresy IP (tzw. *Self-IPs*) do każdej z wymaganych sieci VLAN (*internal*, w celu połączenia BIG-IP z serwerem aplikacyjnym, oraz *external* dla połączeń przychodzących do chronionych aplikacji). Sieci te należy uprzednio utworzyć i przypisać do odpowiednich interfejsów sieciowych urządzenia/maszyny wirtualnej – w tym celu najlepiej zrezygnować ze wstępnego konfiguratora na etapie *Network*, zamiast tego ustawiając je ręcznie [Rys. 8].



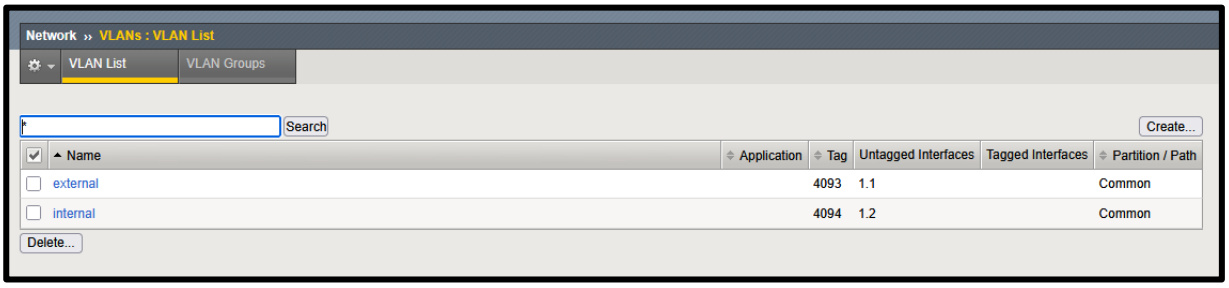
Rys. 7. Wstępny ekran konfiguracyjny BIG-IP

(źródło: opracowanie własne)



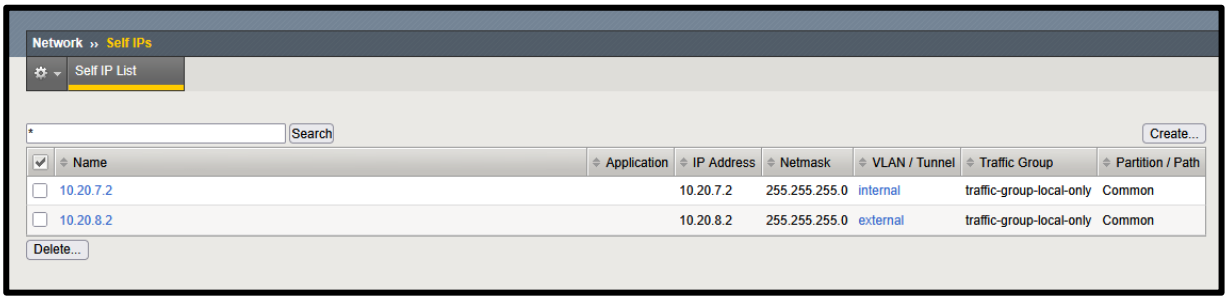
Rys. 8. Ekran wyboru modułów BIG-IP

(źródło: opracowanie własne)



Rys. 9. Ekran konfiguracji sieci VLAN

(źródło: opracowanie własne)



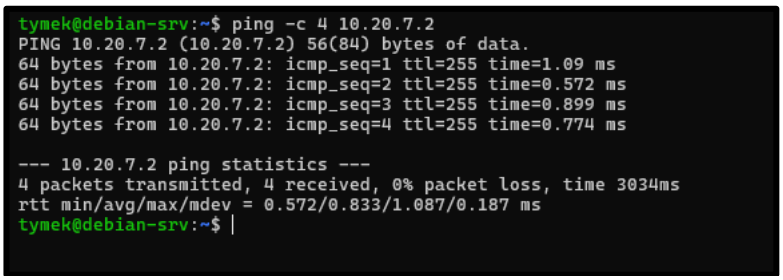
Rys. 10. Ekran konfiguracji adresów IP (Self-IPs)

(źródło: opracowanie własne)

Na potrzeby opracowanego projektu przyjęto następujące ustawienia adresacji BIG-IP:

- Adres *management*: 192.168.60.128/24
- Adres *internal*: 10.20.7.2/24
- Adres *external*: 10.20.8.2/24

W celu weryfikacji poprawności wprowadzonych ustawień, przeprowadzono również test osiągalności instancji BIG-IP z sieci *internal* przy pomocy polecenia *ping* z poziomu serwera aplikacyjnego.



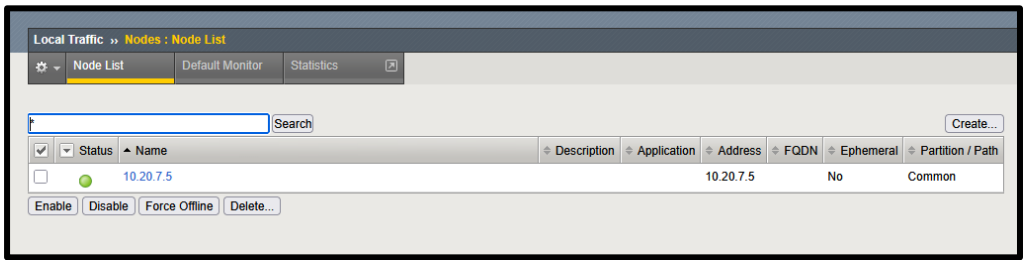
Rys. 11. Test osiągalności BIG-IP z poziomu serwera

(źródło: opracowanie własne)

IV.2. Konfiguracja modułu LTM i dodanie serwera aplikacji

Po skonfigurowaniu podstawowych ustawień platformy BIG-IP, należy przypisać serwer aplikacyjny tak, aby strona WWW była dostępna poprzez system BIG-IP, jednocześnie terminując poprawnie ruch szyfrowany i spełniając tym samym wymaganie funkcjonalne projektu.

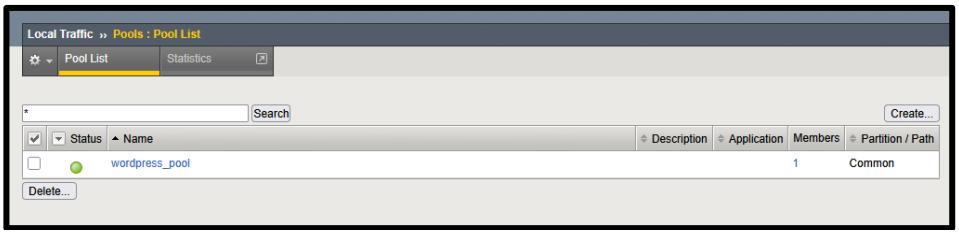
Aby to osiągnąć, w pierwszej kolejności należy wskazać adres IP docelowego serwera, dodając go jako węzeł (z ang. *node*), czyli obiekt wskazujący bezpośrednio na zamierzony, fizyczny serwer. Taką konfigurację można wprowadzić korzystając z panelu Local Traffic / Nodes.



Rys. 12. Ekran konfiguracji węzłów serwerów WWW

(źródło: opracowanie własne)

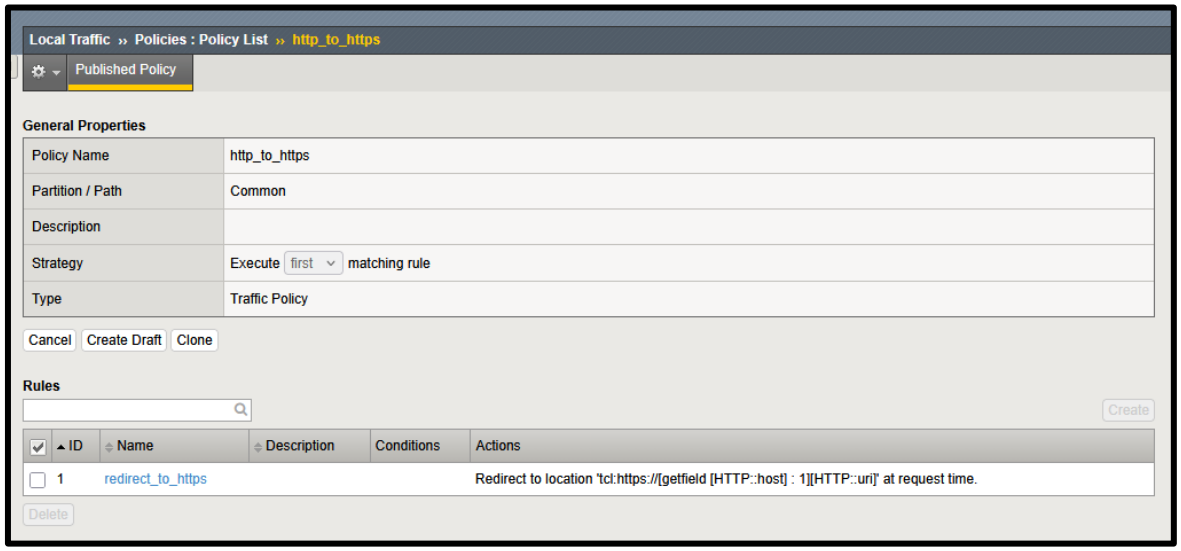
Po wykonaniu tej czynności, wymagane jest przypisanie węzła do puli (z ang. *pool*), która agreguje węzły jako jedną, zarządzalną całość – dzięki temu, posiadając wiele węzłów końcowych (a tym samym wiele redundantnych serwerów aplikacyjnych) BIG-IP realizuje zarządzanie ruchem, inteligentnie kierując zapytania do aplikacji i równomiernie obciążając serwery docelowe zagregowane w jednej puli.



Rys. 13. Ekran konfiguracji puli

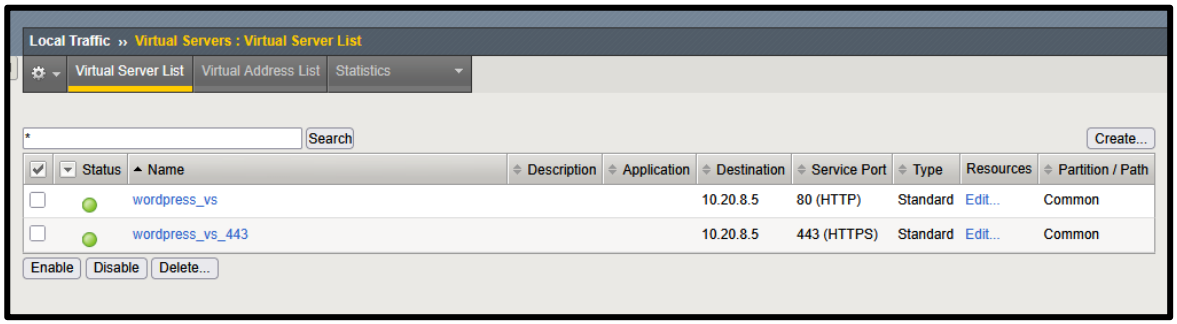
(źródło: opracowanie własne)

W kolejnym kroku należy utworzyć wirtualne serwery (w skrócie VIP, z ang. *Virtual Server*) tak, aby możliwe było zestawienie bezpiecznego, szyfrowanego połączenia SSL/TLS z aplikacją. Obiekt ten bazowo spełnia zadanie dywersyfikacji przychodzącego ruchu pomiędzy węzły zamieszczone w przypiętej puli, jednakże prócz tego realizuje on również funkcję *Reverse Proxy*, a także umożliwia podpięcie reguł iRules oraz polityk bezpieczeństwa (wytworzonych w dalszej części pracy). W aspekcie zapewnienia ruchu SSL/TLS istotnym jest wytworzenie dwóch obiektów VIP– jednego, dla standardowego połączenia HTTP (tj. dla portu 80), oraz drugiego, zestawiającego szyfrowane połączenie HTTPS (poprzez port 443). Należy pamiętać o skonfigurowaniu odpowiedniej polityki LTM przekierowującej połączenia z puli HTTP do HTTPS (tak, aby możliwe było zestawienie wyłącznie bezpiecznego połączenia z aplikacją) oraz aktywowanie tej polityki w ustawieniach pierwszej puli, w zakładce *Resources*.



Rys. 14. Konfiguracja polityki LTM przekierowującej ruch HTTP do HTTPS

(źródło: opracowanie własne)



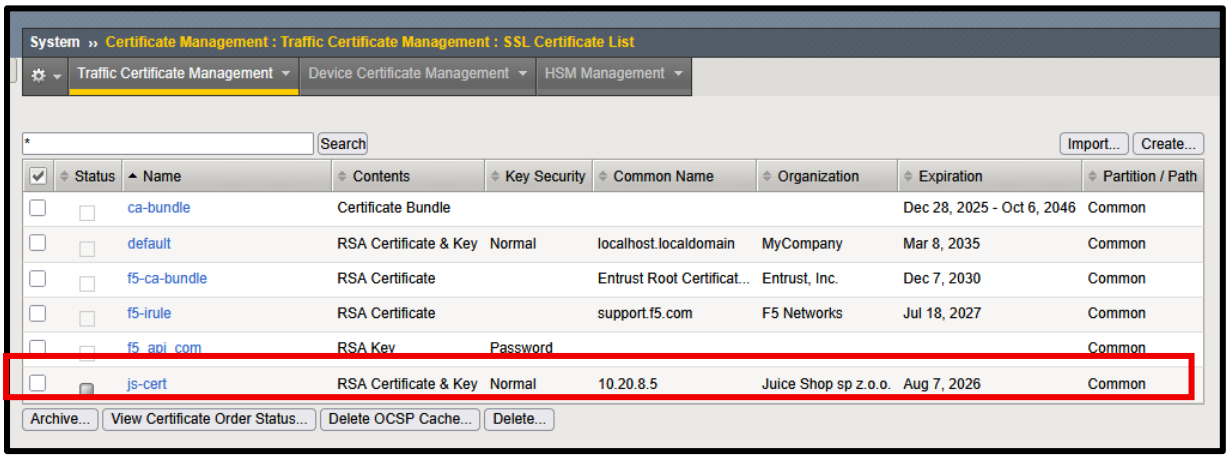
Rys. 15. Ekran konfiguracji wirtualnych serwerów

(źródło: opracowanie własne)

Dla opisywanej konfiguracji, przyjęto poniższe ustawienia docelowych i źródłowych adresów IP dla konfigurowanych obiektów, zapewniające dostęp do aplikacji z dowolnego adresu IP:

- Adres serwera aplikacyjnego: 10.20.7.5/24
- Adres docelowy dla aplikacji: 10.20.8.5/24
- Adres źródłowy: 0.0.0.0/0

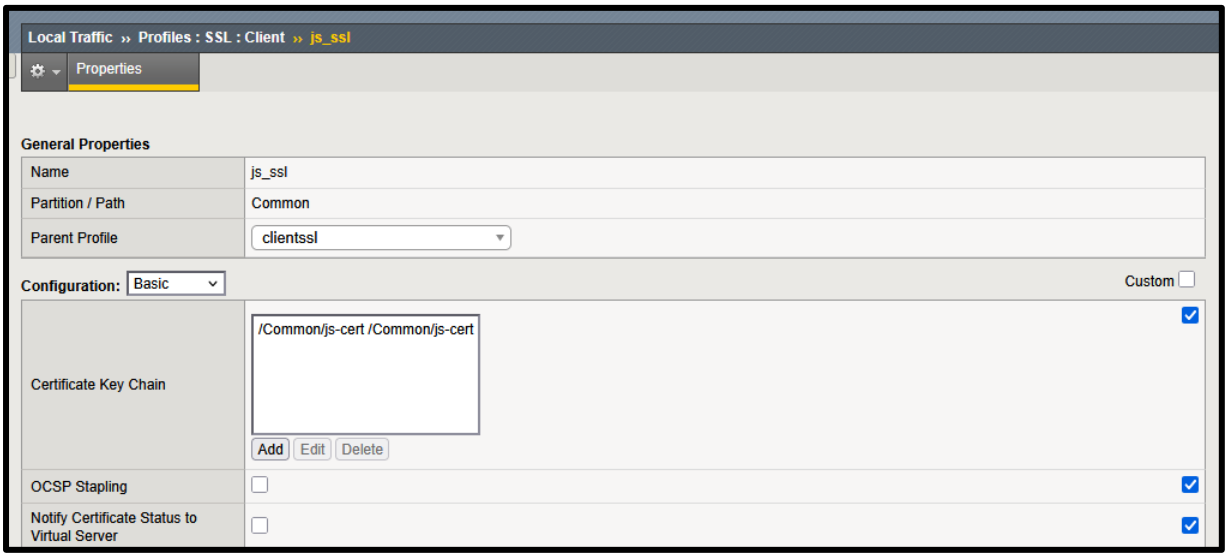
Niemniej istotnym etapem, jest wytworzenie (lub zaimportowanie) certyfikatu i klucza dla szyfrowanego ruchu SSL/TLS – w tym celu, w zakładce System / Certificate Management wybrać należy stosowną opcję i utworzyć/wgrać klucz i certyfikat.



Rys. 16. Ekran zarządzania certyfikatami SSL/TLS wraz z utworzonym certyfikatem

(źródło: opracowanie własne)

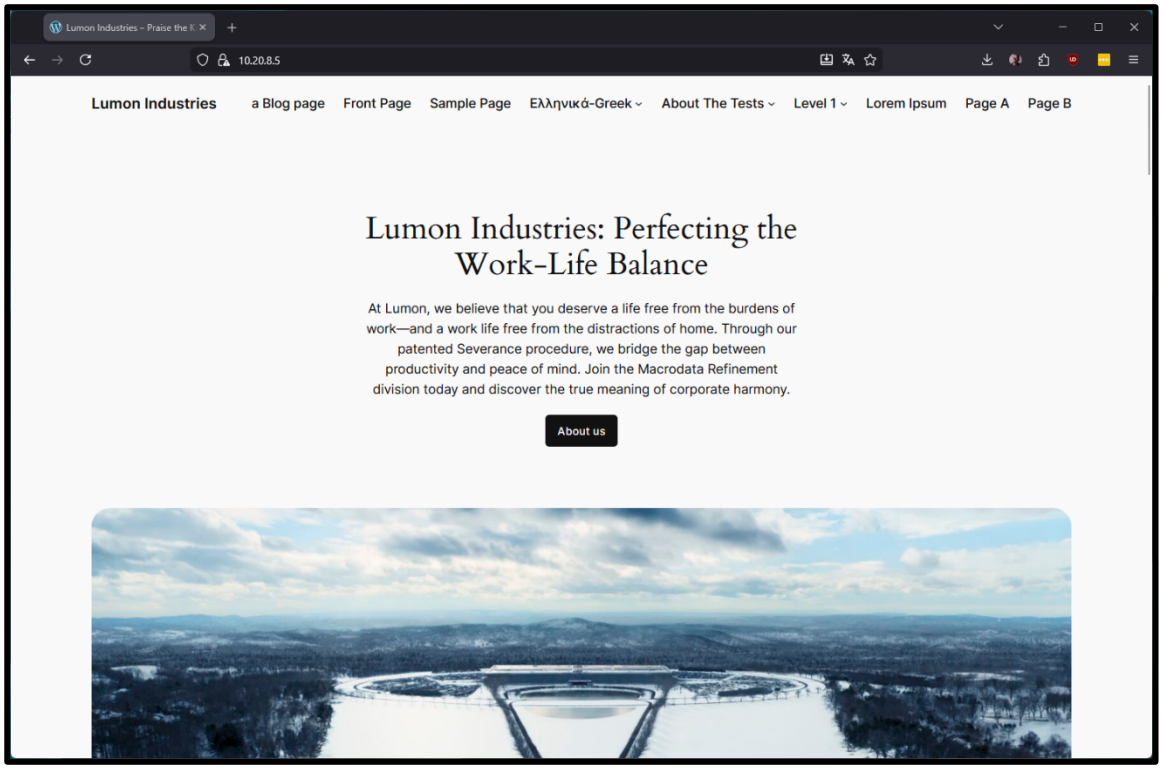
Ostatnim etapem jest utworzenie profilu SSL/TLS oraz wskazanie go na stronie głównej konfiguracji wirtualnego serwera odpowiedzialnego za ruch po protokole HTTPS – podczas konfiguracji profilu należy wskazać wcześniej dodany certyfikat wraz z kluczem.



Rys. 17. Konfiguracja profilu SSL

(źródło: opracowanie własne)

W celu weryfikacji poprawności dotychczasowej konfiguracji, w oknie przeglądarki internetowej uruchomiono aplikację internetową korzystając z wcześniej zdefiniowanego adresu IP wirtualnego serwera (poprzez odwołanie pod adres URL https://10.20.8.5). Poniższy zrzut ekranu przedstawia prawidłowo wczytaną witrynę, a także potwierdza przekierowanie użytkownika na połączenie szyfrowane w ramach sesji HTTPS.



Rys. 18. Zrzut ekranu poprawnie wczytanej aplikacji internetowej

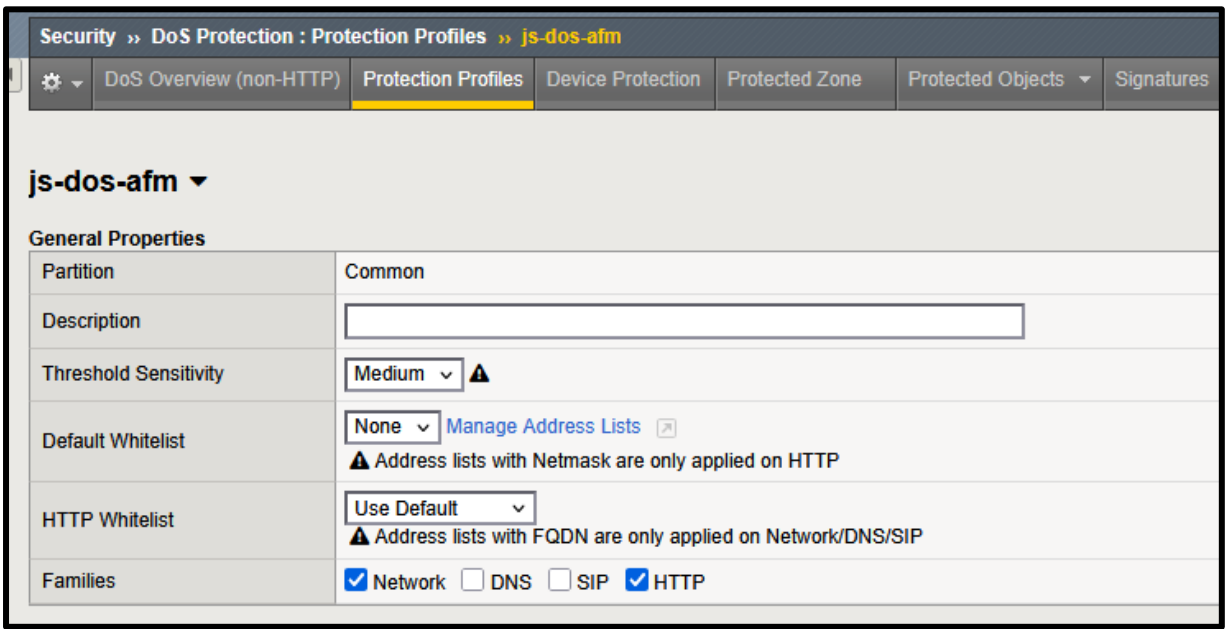
(źródło: opracowanie własne)

IV.3. Konfiguracja polityki ochrony przed atakami DoS

Najistotniejszym z punktu widzenia niniejszej pracy jest prawidłowe skonfigurowanie polityki bezpieczeństwa, zapewniającej skuteczną ochronę przed atakami DoS różnego typu. Należy podkreślić fakt, że aby opracować dokładną ochronę zarówno w warstwach L3/L4, jak i L7, konieczne jest licencjonowanie oraz włączenie wcześniej wymienianych modułów BIG-IP – mianowicie ASM oraz AFM. Jak opisano w drugim rozdziale, pierwszy moduł zapewni ochronę w warstwie aplikacji, podczas gdy drugi zmityguje ataki wolumetryczne na warstwę sieciową i transportową. Dla kompleksowej ochrony muszą one zatem działać równorzędnie.

Konfigurację rozpoczęto od utworzenia polityki bezpieczeństwa w zakładce Security / DoS Protection / Protection Profiles. To w niej zdefiniować i dokładnie skonfigurować należy wartości progowe dla mechanizmów ochrony przed atakami DoS. Najistotniejszym ustawieniem z sekcji *General* jest opcja *Threshold Sensitivity*, określająca ogólną czułość profilu na określone w dalszych częściach ataki DoS.

Możliwe jest również określenie tzw. *white-listy*, zawierającej źródłowe adresy IP, które ignorowane będą w procesie mitygacji ataków DoS – jest to przydatna funkcjonalność np. dla testowania wydajnościowego serwera aplikacji, bez ingerencji modułów ASM/AFM. Ze względu na fakt, iż środowisko laboratoryjne, w którym jest wytwarzane rozwiązanie, umożliwia bezpośrednie połączenie z serwerem aplikacji pomijając BIG-IP, nie zaszła potrzeba konfigurowania specjalnej białej listy.



Rys. 19. Ekran konfiguracji podstawowych opcji polityki ochrony przed DoS

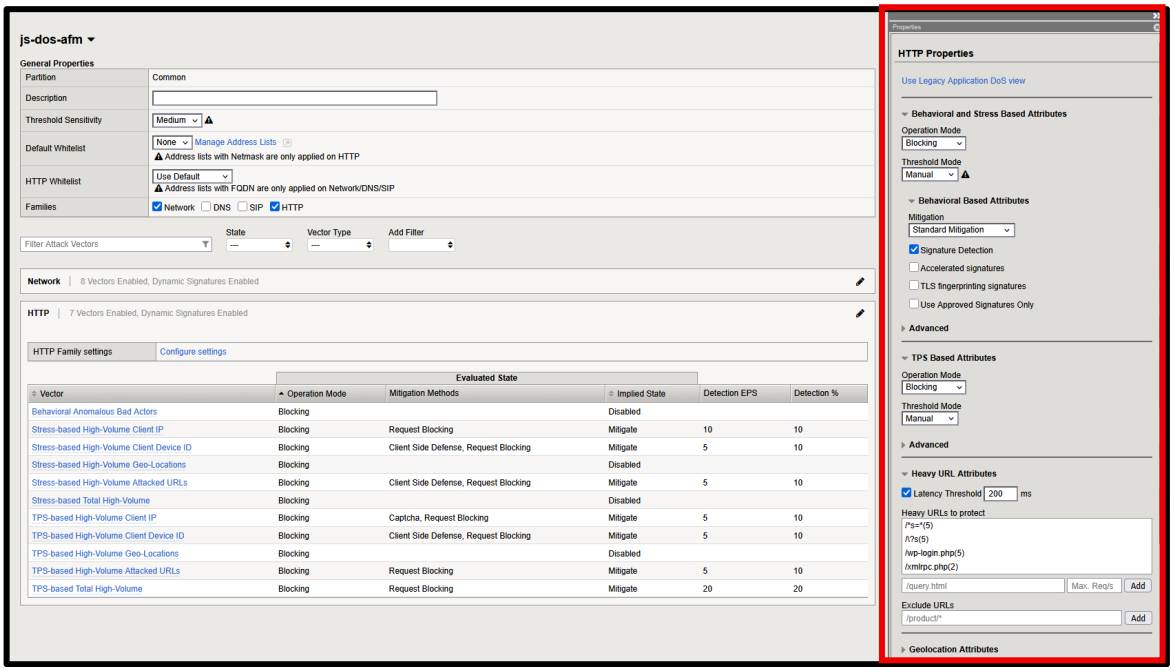
(źródło: opracowanie własne)

W tej sekcji określono również (poprzez zaznaczenie opcji *Network* i *HTTP* w opcji *Families*) grupy ataków, które mają być mitygowane – *Network* agreguje ataki wolumetryczne (na warstwy L3 i L4), natomiast *HTTP* (obsługiwane przez moduł ASM) zawiera sygnatury ataków na warstwę aplikacyjną. Pozostałe opcje pominięto, z uwagi na specyfikę środowiska laboratoryjnego, w tym brak stosowania nazw DNS na rzecz bezpośredniego odwoływania się do adresów IP.

Wybranie wyżej wymienionych opcji poskutkowało wyświetleniem się dwóch kart w dalszej części konfiguratora – to tu znajdują się gotowe sygnatury ataków, które urządzenie F5 BIG-IP jest w stanie mitygować.

IV.3.1. Mitygacja ataków na warstwę aplikacyjną (L7)

W celu rozpoczęcia dostrajania ustawień dotyczących obrony przed atakami na warstwę L7, należy rozwinąć panel HTTP, uprzednio wywołany poprzez zaznaczenie odpowiednich opcji w sekcji *General*. W pierwszej kolejności, przed rozpoczęciem regulowania wartości progowych dla mechanizmów ochronnych, konieczne jest skonfigurowanie ustawień całej sekcji zagrożeń HTTP – są one dostępne pod przyciskiem *Configure settings* w opcji *HTTP Family settings* (panel zaznaczony na czerwono).



Rys. 20. Panel ustawień grupy ataków HTTP w polityce ochrony przed DoS

(źródło: opracowanie własne)

Sekcja ta jest kluczowa w kontekście poprawnego wykrywania i mitygacji ataków w warstwie aplikacji. Na podstawie analizy chronionej aplikacji (WordPress), skonfigurowano powyższe opcje w sposób umożliwiający przetestowanie skuteczności obrony w środowisku laboratoryjnym, o ograniczonych zasobach. Przykładowo, z uwagi na konieczność natychmiastowego egzekwowania ustawianych blokad, ustawiono opcję *Operation Mode* na wartość *Blocking* oraz *Threshold Mode* na *Manual*. W środowisku produkcyjnym zalecanym jest wybranie wartości odpowiednio *Transparent* (tymczasowo, w celu sprofilowania prawidłowego ruchu sieciowego) oraz *Automatic*, aby BIG-IP mogło w inteligentny sposób dobrać odpowiednie wartości na podstawie obciążenia aplikacji. Konieczność ustawienia niskich progów wyzwalania ataku w celu weryfikacji wymusiła jednak zastosowanie opcji manualnych, z pominięciem trybu automatycznego uczenia.

W celu umożliwienia generowania sygnatur w czasie rzeczywistym, zaznaczono również opcję *Signature Detection* – dzięki niej, mechanizm *Behavioral DoS* może wytwarzać dynamiczne reguły blokujące, np. dla konkretnego nagłówka *User-Agent* lub wzorca w adresie URL. Pozwoli to zmniejszyć ryzyko blokady legalnych użytkowników podczas potencjalnego ataku.

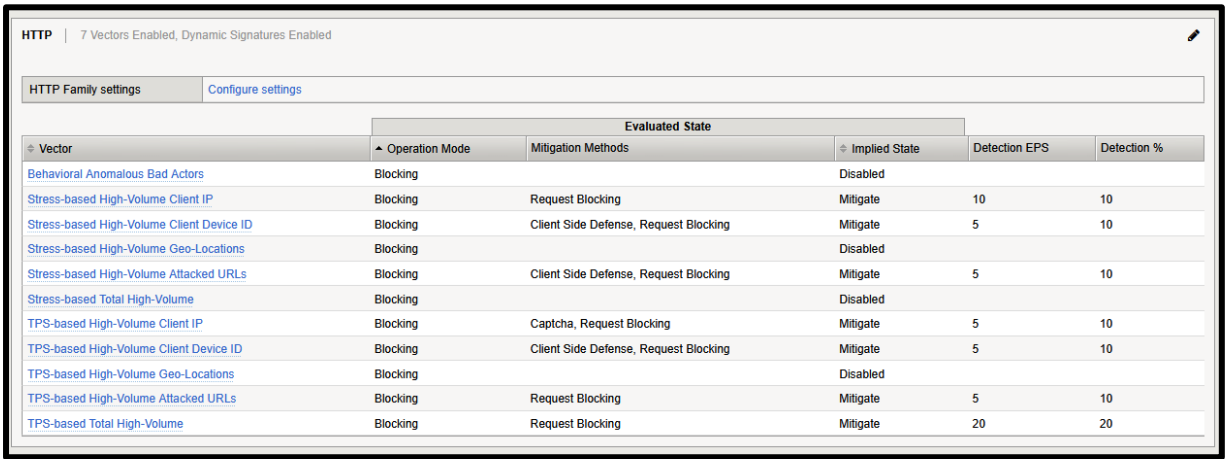
Analogicznie do sekcji behawioralnej, w sekcji poświęconej konfiguracji mitygacji na podstawie liczby transakcji na sekundę (TPS, z ang. *Transactions Per Second*) zastosowano tryb *Blocking* oraz *Manual Thresholds*. Umożliwia to zdefiniowanie sztywnego limitu transakcji na sekundę, po przekroczeniu którego system uznaje ruch za anomalię i blokuje dalsze połączenia.

Ostatnią istotną sekcją, z punktu widzenia środowiska testowego, jest sekcja *Heavy URL Attributes*. Odpowiada ona za ochronę konkretnych ścieżek aplikacji, które

generują wysokie obciążenie serwera (np. zapytania do bazy danych). W ranach tej sekcji zdefiniowano listę newralgicznych punktów systemu WordPress, w tym pliki: *wp-login.php*, odpowiedzialny za logowanie oraz *xmlrpc.php*, umożliwiający zdalne połączenia z wykorzystaniem API, a także ścieżkę */?s=* wykorzystywaną do przeszukiwania witryny. Ochrona tych zasobów jest priorytetowa, gdyż są one częstym celem ataków DoS na aplikacje WordPress. Parametr *Latency Threshold* ustawiono na wartość 200 ms – oznacza to, że jeśli czas odpowiedzi serwera dla danego zasobu przekroczy tę wartość, system obejmie go wzmożonym monitorowaniem.

Pozostałe opcje w omawianym panelu dotyczą m.in. ograniczeń wynikających z lokalizacji użytkownika (tzw. *Geo IP*), gdzie możliwe jest zablokowanie dostępu do aplikacji z określonych miejsc, lub personalizacji zapytania CAPTCHA, wysyłanego do klienta w celu dodatkowej weryfikacji, jeśli BIG-IP uzna ruch za podejrzany (lub generowany przez automat programowy). Mając na uwadze, że system ochrony wdrożono w środowisku laboratoryjnym opcje te nie są istotne. Należy zaznaczyć, że w przypadku wdrażania rozwiązania do środowiska produkcyjnego warto te ustawienia (szczególnie związane z lokalizacją) odpowiednio skonfigurować.

Sygnatury ataków dostępne w ramach grupy HTTP zasadniczo dzielą się na dwa rodzaje – pierwsza, dotyczy mitygacji ataków na podstawie analizy obciążeniowej oraz ruchu zintensyfikowanego względem ruchu normalnego (sygnatury nazwane *Stress-based […]*). Z kolei druga (*TPS-Based […]*) – identyfikuje i blokuje ataki DoS wyłącznie na podstawie limitu transakcji na sekundę, zdefiniowanego w ramach każdej sygnatury. Dla skutecznego działania, mechanizmy *TPS*-Based traktować należy jako pierwszą linię obrony przed prostymi atakami, natomiast *Stress-based* jako bardziej zaawansowane, aktywowane w momencie wykrycia degradacji wydajności samego serwera. Rozwiązanie BIG-IP jest w stanie profilować ataki na podstawie adresu IP sprawcy, jego lokalizacji, unikalnego *Device-ID* (tzw. *fingerprintu*), a także ilości wysyłanych żądań w kierunku ściśle chronionych adresów URL oraz ogólnego natężenia ruchu.



HTTP | 7 Vectors Enabled, Dynamic Signatures Enabled

HTTP Family settings | Configure settings

Vector	Operation Mode	Mitigation Methods	Evaluated State: Implied State	Detection EPS	Detection %
Behavioral Anomalous Bad Actors	Blocking		Disabled		
Stress-based High-Volume Client IP	Blocking	Request Blocking	Mitigate	10	10
Stress-based High-Volume Client Device ID	Blocking	Client Side Defense, Request Blocking	Mitigate	5	10
Stress-based High-Volume Geo-Locations	Blocking		Disabled		
Stress-based High-Volume Attacked URLs	Blocking	Client Side Defense, Request Blocking	Mitigate	5	10
Stress-based Total High-Volume	Blocking		Disabled		
TPS-based High-Volume Client IP	Blocking	Captcha, Request Blocking	Mitigate	5	10
TPS-based High-Volume Client Device ID	Blocking	Client Side Defense, Request Blocking	Mitigate	5	10
TPS-based High-Volume Geo-Locations	Blocking		Disabled		
TPS-based High-Volume Attacked URLs	Blocking	Request Blocking	Mitigate	5	10
TPS-based Total High-Volume	Blocking	Request Blocking	Mitigate	20	20

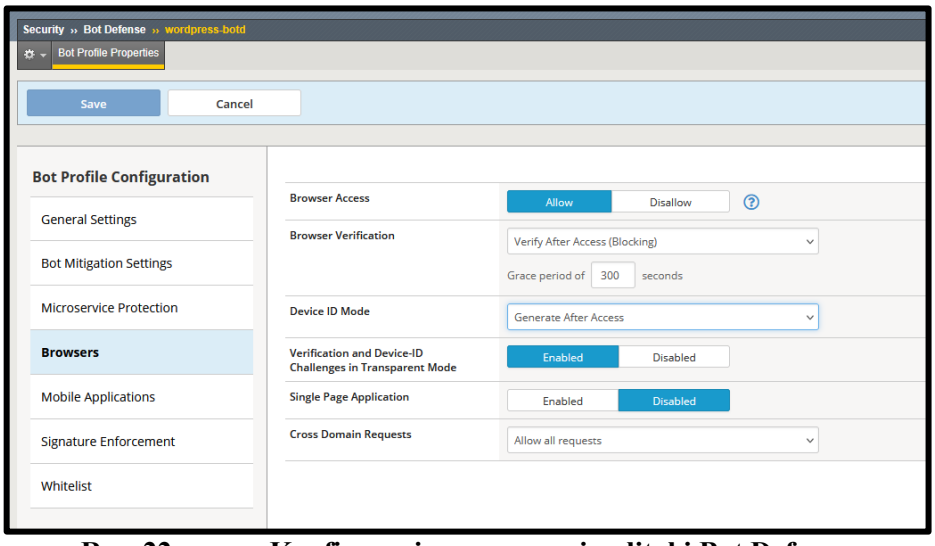
Rys. 21. Ekran ustawień wektorów ataków warstwy L7

(źródło: opracowanie własne)

Najważniejszymi parametrami są progi detekcji (tu: *Detection EPS* oraz *Detection %*) – to one określają, jakie obciążenie musi nastąpić, by wywołana została obrona lub całkowita blokada. Na potrzeby testów wartości te zostały celowo zaniżone do poziomu 5-20 EPS tak, aby możliwym było wykonanie ataku oraz skuteczna ochrona z poziomu jednej stacji roboczej. W realnym, produkcyjnym środowisku wartości te powinny zostać dobrane automatycznie (przy pomocy trybu *Automatic*) lub ustawione wykorzystując znacznie wyższą wartość, wyznaczoną na podstawie analizy ruchu użytkowników oraz obciążenia samego BIG-IP.

Na etapie wdrożenia systemu ochrony zastosowano również strategię stopniowego reagowania na atak – w pierwszej kolejności działanie podejmują mechanizmy takie jak *Client Side Defense* w celu weryfikacji przeglądarki, oraz generujące żądania *CAPTCHA*. Dopiero w przypadku niepowodzenia lub nadmiernego obciążenia, system całkowicie blokuje kolejne połączenia, odrzucając je, tym samym chroniąc serwer aplikacji przed przeciążeniem.

Wartymi osobnego opisania są mechanizmy *Device ID*, wykrywające potencjalne zagrożenie na podstawie cech charakterystycznych przeglądarki. Aby mogły one skutecznie blokować ataki, konieczne jest wytworzenie polityki *Bot Defense*, odpowiedzialnej za ochronę przed automatycznymi botami i crawlerami. Politykę taką należy utworzyć, przechodząc do sekcji Security / Bot Defense / Bot Defense Profiles, oraz wybierając opcję *Create*. Po utworzeniu polityki, korzystając z domyślnych ustawień, należy w sekcji *Browsers* z menu kontekstowego *Device ID Mode* wybrać opcję *Generate After Access* – umożliwi to poprawne działanie sygnatur wykorzystujących mechanizm *Device ID*. Tak skonfigurowaną politykę Bot Defense należy wówczas podpiąć do wirtualnego serwera HTTPS, w sekcji *Security* w jego ustawieniach (nie jest wymagane przypięcie polityki do obiektu obsługującego połączenia HTTP z tego względu, że jest on wykorzystywany wyłącznie do przekierowania użytkownika w tryb transmisji szyfrowanej).



Rys. 22. Konfiguracja wymaganej polityki Bot Defense

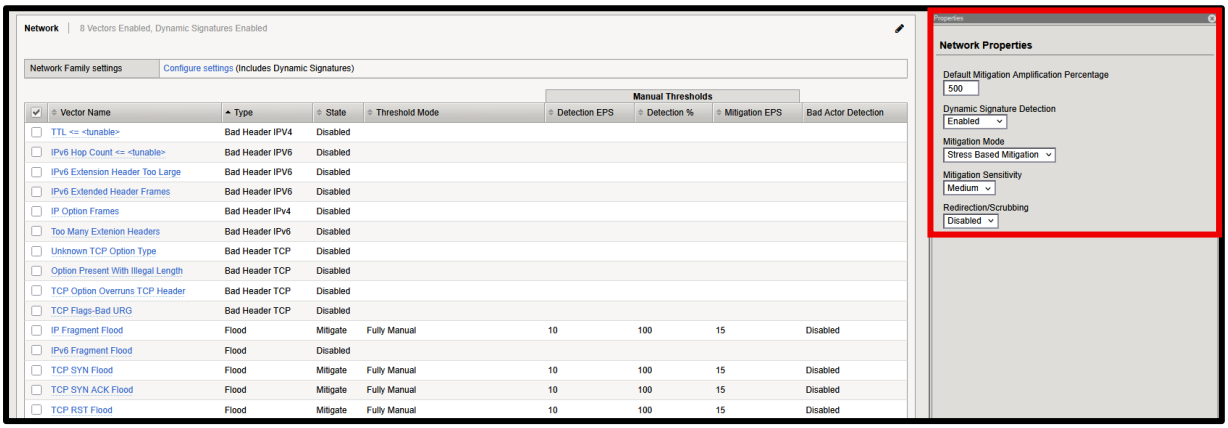
(źródło: opracowanie własne)

Opisana w niniejszym podrozdziale konfiguracja umożliwia skuteczną mitygację ataków DoS w warstwie aplikacyjnej – takich, jak Low and Slow, HTTP Flood, niezależnie od środowiska oraz wolumenu, z jakiego korzysta atakujący.

IV.3.2. Mitygacja ataków na warstwę sieciową i transportową (L3 i L4)

Implementacja systemu ochrony przed atakami wolumetrycznymi warstwy L3 i L4 jest o tyle istotna, że stanowi pierwszą linię obrony w przypadku potencjalnego zagrożenia. Ponieważ dotyczy ona niższych warstw modelu OSI niż warstwa aplikacyjna, realizowana jest w całości poprzez moduł AFM, chroniąc zarówno moduł ASM przed nadmiernym obciążeniem, jak i zasoby samej instancji BIG-IP.

Konfiguracja odbywa się na tej samej stronie, którą wcześniej opisano, tzn. w polityce ochrony przed atakami DoS. Jednakże w tym przypadku, wybrać oraz rozwinąć należy sekcję *Network*, zawierającą wektory ataków warstwy L3 i L4. Tu, analogicznie jak poprzednio, należy wpierw ustawić ogólne parametry całej sekcji, wybierając opcję *Configure settings*.



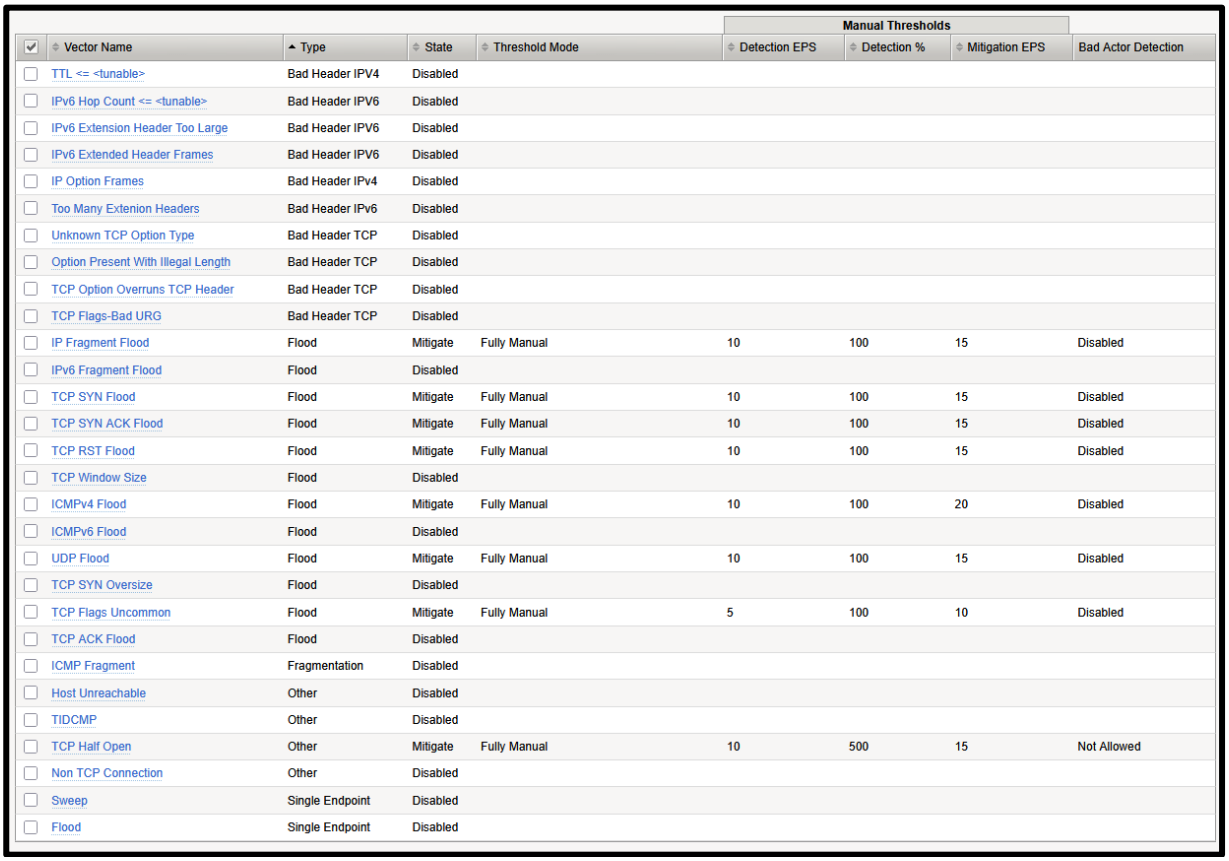
Rys. 23. Panel ustawień grupy ataków *Network* w polityce ochrony przed DoS

(źródło: opracowanie własne)

Poszczególne opcje dotyczą ogólnego działania sygnatur w tej sekcji. Kluczowym elementem jest aktywacja funkcji *Dynamic Signature Detection*, która umożliwia automatyczne generowanie precyzyjnych reguł blokujących w czasie rzeczywistym (podobnie, jak opcja *Signature Detection* w ustawieniach grupy HTTP). Ustawienie *Stress Based Mitigation* w *Mitigation Mode* zapewnia równowagę między bezpieczeństwem, a dostępnością usług, poprzez gradacyjne zwiększanie działań mitygacyjnych bazując na obciążeniu urządzenia. Całość dopełnia ustawienie parametru *Default Mitigation Amplification Percentage* na poziomie 500%, co tworzy bezpieczny bufor dla legalnych, nagłych skoków ruchu (opisywane w podrozdziale I.2.2 zjawisko *flash crowd*), minimalizując ryzyko wystąpienia fałszywych alarmów w normalnych warunkach produkcyjnych.

Sygnatury ataków dostępne w ramach tej sekcji, podzielić można według wielu kryteriów. W tym przypadku określono trzy najistotniejsze grupy: pierwszą są ataki wykorzystujące protokół TCP – aktywowane mechanizmy zapewnią ochronę przed

zagrożeniami typu TCP SYN Flood, TCP SYN ACK Flood oraz TCP RST Flood, nie dopuszczając do wyczerpania się tablicy stanów połączeń. Prócz tego włączenie mitygacji ataków TCP Half Open oraz TCP Flags Uncommon pozwala zabezpieczyć serwer przed próbami nawiązywania niepełnych sesji oraz przesyłaniem pakietów z nielegalnymi kombinacjami flag, często służącymi do rekonesansu sieci lub omijania prostych zapór ogniowych. Drugą grupą ataków są ataki wolumetryczne – tu skuteczne okażą się sygnatury UDP Flood oraz ICMPv4 Flood. W ten sposób ochronione zostanie pasmo sieciowe przed nasyceniem go wrogim ruchem. Ostatnią grupę stanowią ataki fragmentacyjne, celujące w przeciążenie procesora atakowanego urządzenia, próbującego złożyć na nowo pofragmentowane pakiety. Aktywacja sygnatury *IP Fragment Flood* umożliwia skuteczną mitygację tego typu ataku.



					Manual Thresholds			
☑	Vector Name	Type	State	Threshold Mode	Detection EPS	Detection %	Mitigation EPS	Bad Actor Detection
☐	TTL <= <tunable>	Bad Header IPV4	Disabled					
☐	IPv6 Hop Count <= <tunable>	Bad Header IPV6	Disabled					
☐	IPv6 Extension Header Too Large	Bad Header IPV6	Disabled					
☐	IPv6 Extended Header Frames	Bad Header IPV6	Disabled					
☐	IP Option Frames	Bad Header IPv4	Disabled					
☐	Too Many Extenion Headers	Bad Header IPv6	Disabled					
☐	Unknown TCP Option Type	Bad Header TCP	Disabled					
☐	Option Present With Illegal Length	Bad Header TCP	Disabled					
☐	TCP Option Overruns TCP Header	Bad Header TCP	Disabled					
☐	TCP Flags-Bad URG	Bad Header TCP	Disabled					
☐	IP Fragment Flood	Flood	Mitigate	Fully Manual	10	100	15	Disabled
☐	IPv6 Fragment Flood	Flood	Disabled					
☐	TCP SYN Flood	Flood	Mitigate	Fully Manual	10	100	15	Disabled
☐	TCP SYN ACK Flood	Flood	Mitigate	Fully Manual	10	100	15	Disabled
☐	TCP RST Flood	Flood	Mitigate	Fully Manual	10	100	15	Disabled
☐	TCP Window Size	Flood	Disabled					
☐	ICMPv4 Flood	Flood	Mitigate	Fully Manual	10	100	20	Disabled
☐	ICMPv6 Flood	Flood	Disabled					
☐	UDP Flood	Flood	Mitigate	Fully Manual	10	100	15	Disabled
☐	TCP SYN Oversize	Flood	Disabled					
☐	TCP Flags Uncommon	Flood	Mitigate	Fully Manual	5	100	10	Disabled
☐	TCP ACK Flood	Flood	Disabled					
☐	ICMP Fragment	Fragmentation	Disabled					
☐	Host Unreachable	Other	Disabled					
☐	TIDCMP	Other	Disabled					
☐	TCP Half Open	Other	Mitigate	Fully Manual	10	500	15	Not Allowed
☐	Non TCP Connection	Other	Disabled					
☐	Sweep	Single Endpoint	Disabled					
☐	Flood	Single Endpoint	Disabled					

Rys. 24. Ekran ustawień wektorów ataków warstw L3/L4

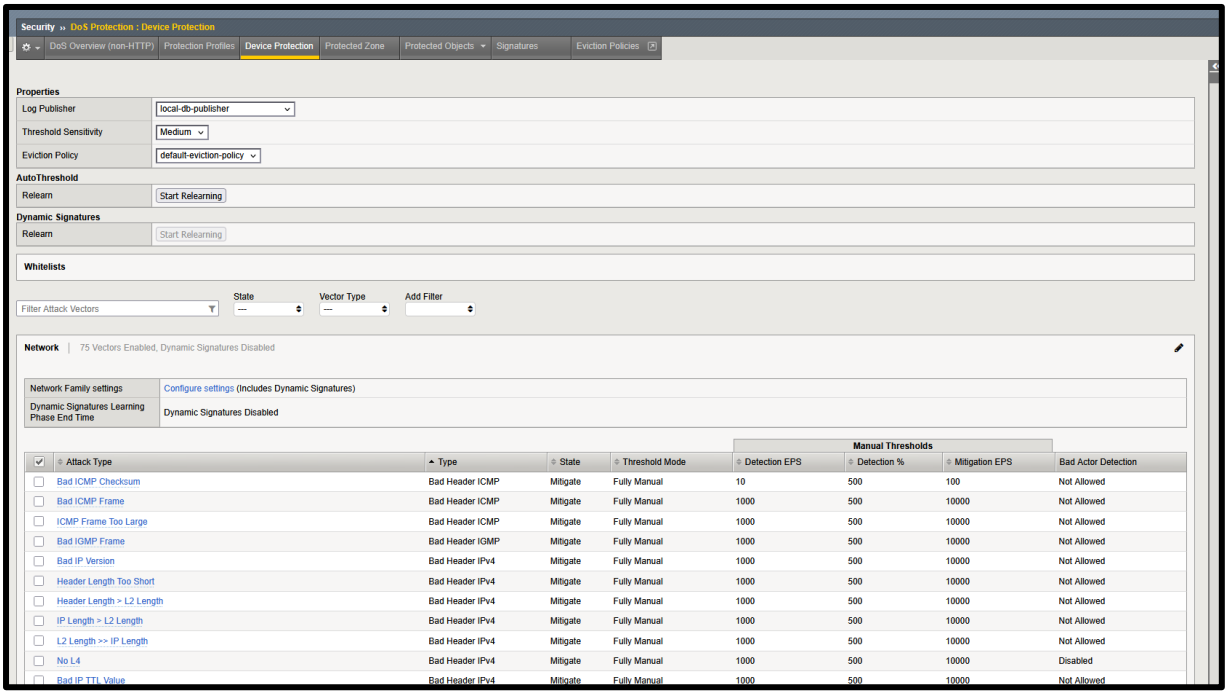
(źródło: opracowanie własne)

Konfiguracja sygnatur dotyczących ochrony przed atakami wolumetrycznymi opiera się głównie na granularnym doborze ustawień dla poszczególnych sygnatur. Ponownie, z uwagi na wdrażanie systemu ochrony w środowisku laboratoryjnym, pewne ustawienia mogą odbiegać od typowych, zalecanych wartości dla produkcyjnych wdrożeń.

W celu skonfigurowania manualnych wartości progów detekcji, przestawić należy uprzednio opcję *Threshold Mode* na wartość *Fully Manual*. Takie działanie umożliwia określenie parametrów odpowiednio nisko, dla celów testowych.

W środowisku produkcyjnym opcja ta powinna zostać ustawiona na tryb w pełni lub półautomatyczny. Parametr *Detection EPS* określa minimalną liczbę pakietów na sekundę, po przekroczeniu której system reaguje na zdarzenie. *Detection %* definiuje z kolei wymagany procentowy wzrost natężenia ruchu względem wcześniejszych wartości bazowych, który musi nastąpić, aby został wywołany alert potencjalnego ataku. Ostatnim istotnym parametrem do zdefiniowania jest *Mitigation EPS*, czyli ostateczny, krytyczny próg wielkości ruchu, po przekroczeniu którego BIG-IP rozpoczyna aktywne zwalczanie zagrożenia.

Przy okazji omawiania ochrony aplikacji internetowej przed atakami DoS warstwy L3/L4, warto odnotować funkcjonalność ochrony przed nimi także samej instancji BIG-IP. Umożliwiają to ustawienia dostępne w sekcji *Device Protection*, w zakładce *Security / DoS Protection*. Sposób konfiguracji danych sygnatur jest identyczny względem zdefiniowanej wcześniej polityki ochrony aplikacji internetowej, wspomnieć należy jednak o wiele większej liście dostępnych sygnatur, a także o dużo wyższych predefiniowanych wartościach progowych. Domyślnie są one w znacznej części włączone, zatem na potrzeby niniejszej pracy pozostawiono je bez zmian.



Rys. 25. Fragment ekranu konfiguracji ochrony BIG-IP przed atakami DoS

(źródło: opracowanie własne)

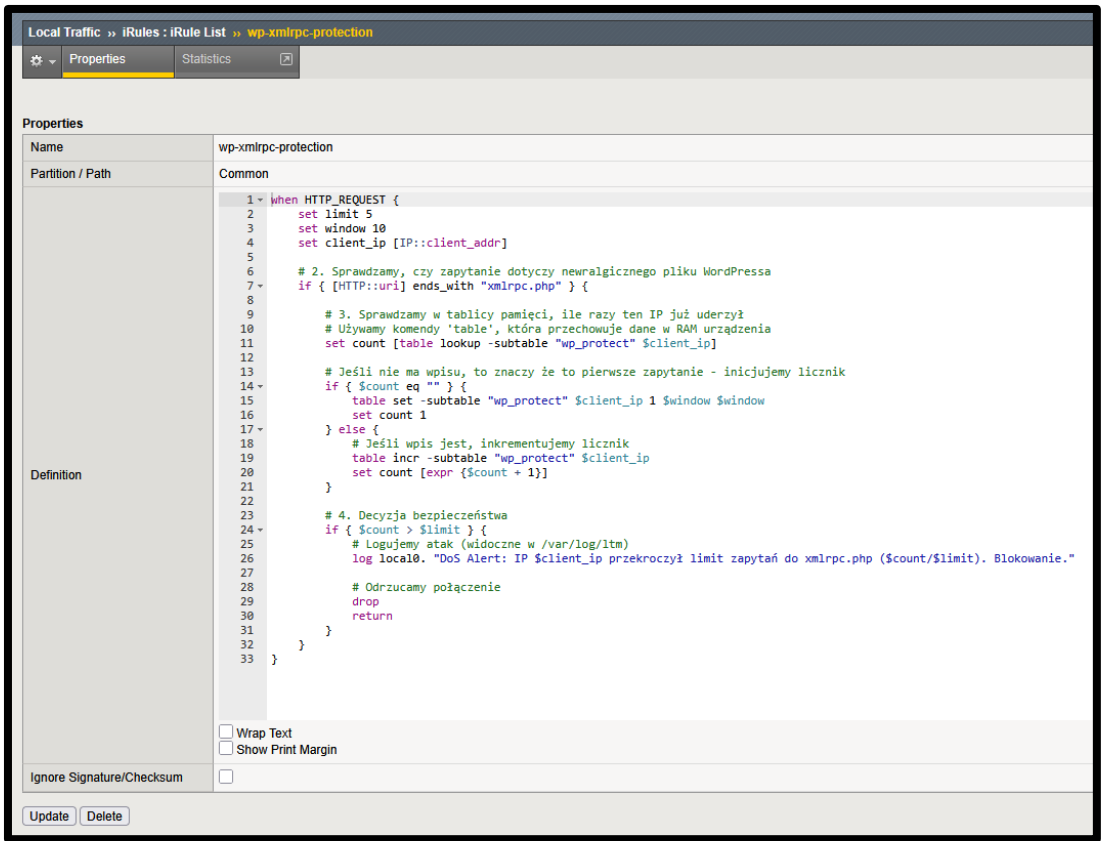
Zaproponowane ustawienia polityki ochrony zapewniają skuteczne odparcie ataków DoS w warstwach sieciowych i transportowych, eliminując przy tym ryzyko wysycenia łącza oraz utraty dostępności zarówno chronionej aplikacji internetowej, jak i samego systemu BIG-IP. Tym samym zakłada się, że wymagania projektowe w tym zakresie zostały spełnione, co poddano weryfikacji w rozdziale V.

IV.4. Dodatkowa konfiguracja ochrony przy pomocy skryptów iRules

Oprócz gotowej i skonfigurowanej polityki ochrony, istnieje również możliwość własnoręcznego, bardzo dokładnego określenia zachowania systemu ochrony w przypadku ataku, korzystając z technologii skryptów iRules. W ramach wykazania skuteczności działania tej technologii oraz zgodnie z tematem niniejszej pracy, przygotowano regułę iRule (o nazwie *wp-xmlrpc-protection*) mającą za zadanie chronić specyficzny punkt ataku na aplikacje WordPress – zalewanie pliku */xmlrpc.php* masowymi zapytaniami HTTP Flood.

Reguła wykorzystuje mechanizm tablic w pamięci operacyjnej urządzenia (komenda *table*), zliczając żądania pochodzące z pojedynczego adresu IP skierowane do chronionego adresu. Przekroczenie progu 5 zapytań w oknie czasowym 10 sekund skutkuje natychmiastowym odrzuceniem pakietu (akcja *drop*) oraz wygenerowaniem wpisu w logach systemowych. Rozwiązanie to stanowi dobrą alternatywę dla pełnych polityk bezpieczeństwa, umożliwiając szybką mitygację nagłych (a szczególnie nowych) ataków aplikacyjnych. Kod skryptu iRule załączono do niniejszej pracy w pliku pod nazwą *wp-xmlrpc-protection-irule.txt* (widoczny jest on również na Rysunku 25).

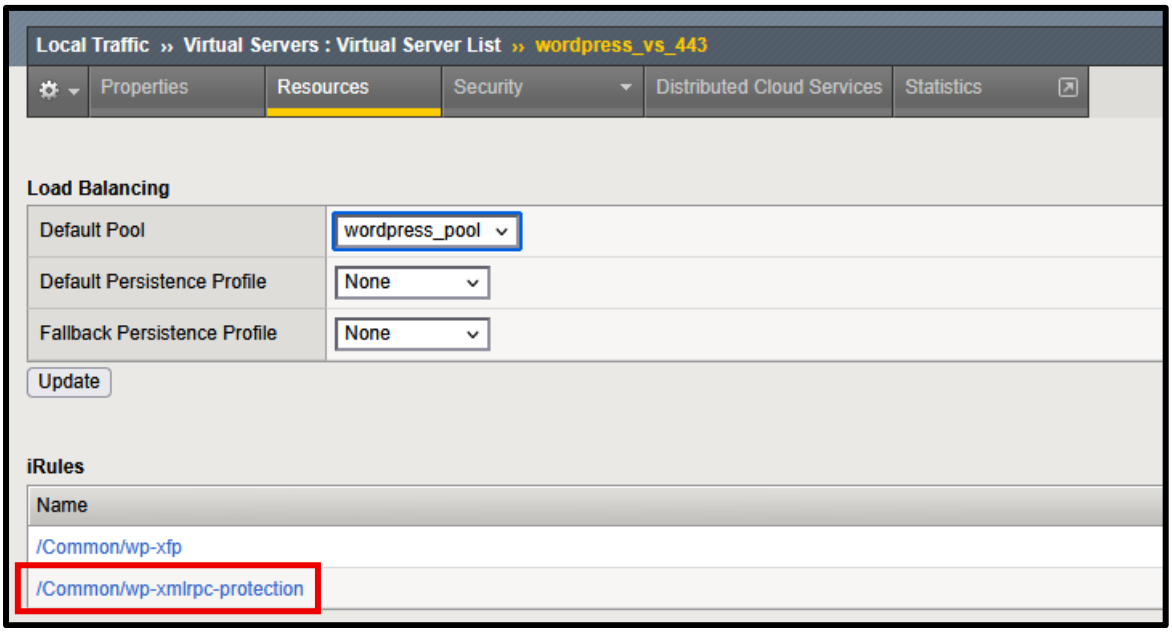
Skrypty iRule definiowane są w sekcji *Local Traffic / iRules / iRule List*. W sekcji tej, wykorzystując przycisk *Create* możliwe jest utworzenie nowego, pustego skryptu, w którym umieścić należy przygotowany kod.



Rys. 26. Zrzut ekranu kodu skryptu iRule blokującego połączenia z *xmlrpc.php*

(źródło: opracowanie własne)

Po zapisaniu skryptu, należy go aktywować w konfiguracji serwera wirtualnego, obsługującego ruch do chronionej aplikacji, co zaprezentowano na rysunku 26.



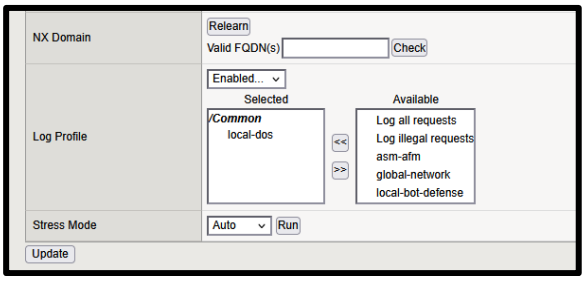
Rys. 27. Ekran przypisywania skryptów iRules do serwera wirtualnego

(źródło: opracowanie własne)

IV.5. Konfiguracja systemu monitorowania zdarzeń

Ostatnim, wymaganym przez założenia funkcjonalne projektu zadaniem, jest odpowiednie skonfigurowanie raportowania oraz monitorowania zdarzeń związanych z bieżącymi atakami DoS. W przypadku omawianego w poprzednim punkcie skryptu iRule, zdarzenia te są raportowane do pliku logów modułu LTM, znajdującego się w lokalizacji */var/log/ltm* – możliwe jest przeglądanie tych zdarzeń zarówno z poziomu interfejsu WWW BIG-IP, jak i poprzez konsolę SSH.

Przygotowana wcześniej polityka ochrony wymaga jednak odrębnego skonfigurowania, poprzez zmianę profilu logującego (z ang. *Log Profile*) w konfiguracji serwera wirtualnego. BIG-IP zawiera domyślnie skonfigurowany profil *local-dos*, który zapewnia monitorowanie i raportowanie bieżących zdarzeń i anomalii z zakresu ataków DoS. Poprzez menu w sekcji *Security / Policies* w kreatorze konfiguracji serwera wirtualnego, przypisać należy wyżej wymieniony profil do serwera oraz zatwierdzić zmiany.



Rys. 28. Ekran konfiguracji profilu logowania dla serwera wirtualnego

(źródło: opracowanie własne)

Rozdział V. Przeprowadzenie testów i opracowanie wniosków

Zwieńczeniem projektowanego rozwiązania ochrony jest weryfikacja skuteczności zaimplementowanych mechanizmów bezpieczeństwa w warunkach symulowanego ataku DoS. Badania przeprowadzono w oparciu o analizę porównawczą, zestawiając ze sobą zachowanie serwera aplikacyjnego w dwóch scenariuszach: w konfiguracji pierwotnej (bez dedykowanej ochrony) oraz po wdrożeniu platformy F5 BIG-IP. Testy obejmują pełne spektrum zagrożeń, począwszy od ataków wolumetrycznych warstwy sieciowej (L3/L4), aż po ataki wyczerpania zasobów w warstwie aplikacji (L7).

V.1. Środowisko testowe i metodyka badań

Do przeprowadzenia testowych ataków posłużono się przygotowanym specjalnie do tego celu środowiskiem testowym, w skład którego wchodzi m.in. maszyna wirtualna z systemem Kali Linux. Maszyna ta podłączona została do sieci *external* wirtualizowanego środowiska, symulując tym samym połączenie z zewnątrz. Ponadto wykorzystano autorskie skrypty, narzędzie Grafana k6, a także oprogramowanie Wireshark, umozliwiające analizę wychodzącego i przychodzącego ruchu sieciowego. Trwające podczas testów ataki DoS obserwowano również w dedykowanym panelu systemu TMOS BIG-IP (*DoS Dashboard*) oraz w dziennikach zdarzeń modułu LTM, poprzez odczyt zawartości pliku */var/log/ltm*.

Przygotowane skrypty służą za narzędzie do testowania wydajności opracowanego rozwiązania – pierwszy, o nazwie *dos-test.sh* będący skryptem Bash dla systemu Linux, integruje różne narzędzia specjalistyczne (hping3, slowhttptest, siege, thc-ssl-dos, curl) do wykonania żądanego ataku, zarówno w warstwach L3/L4, jak i L7. Zapewnia użytkownikowi intuicyjny interfejs umożliwiający wybór testu oraz jego siłę, a także implementuje tryb w pełni automatyczny, wykonujący każdy test po kolei, z odpowiednią przerwą pomiędzy każdym z nich. Przygotowano również skrypty dla narzędzia k6 – symulują one trzy scenariusze ataków: obciążenie wyszukiwarki WordPress (poprzez wywołania adresu /?s= z losową treścią), atak na obiekt /xmlrpc.php, oraz atak na formularz logowania dostępny pod adresem /wp-login.php. Każdy z testów wykonywany jest sekwencyjnie, a liczba wątków wynosi od 100 do 150 – w środowisku testowym zakres ten jest wsytarczający do przeprowadzenia skutecznego ataku. Ponadto na potrzeby testów przygotowano dodatkowy skrypt, zarówno atakujący bezpośrednio serwer, jak również adres IP wirtualnego serwera, uruchomionego w ramach platformy BIG-IP.

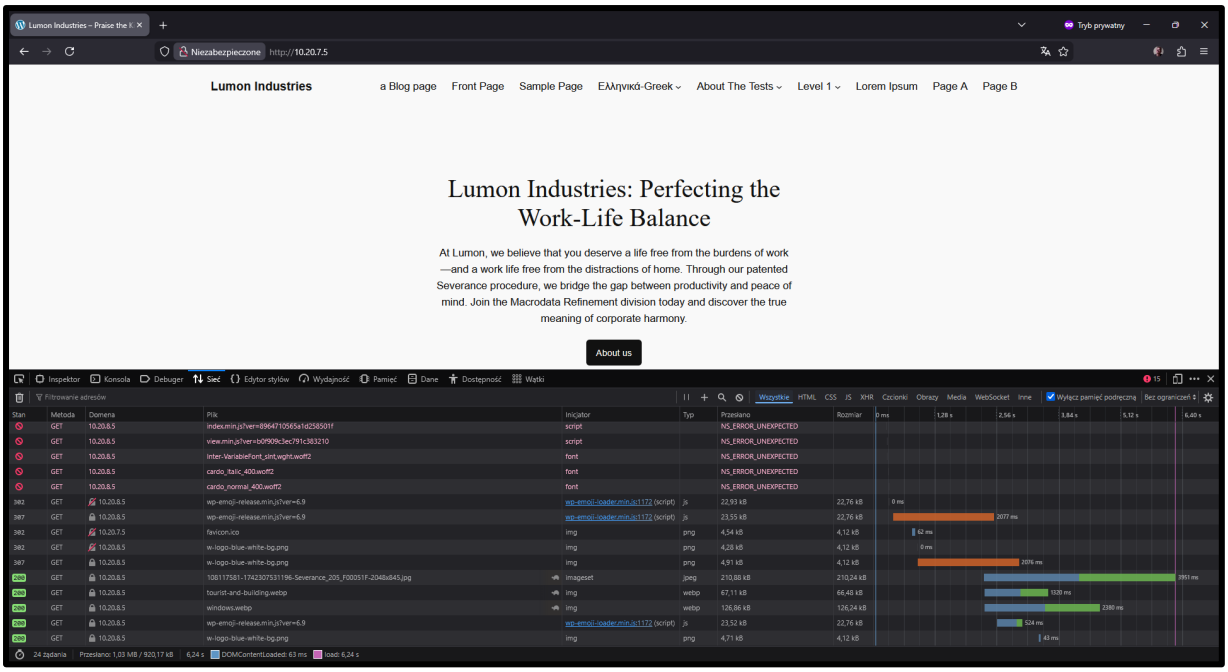
Testy przy pomocy każdego z wyżej opisanych narzędzi zakładają, że aplikacja jest cały czas dostępna podczas wykonywania testu – sprawdzenia tego dokonuje się poprzez załadowanie aplikacji w przeglądarce internetowej uruchomionej na stacji użytkownika końcowego w trybie incognito (by uniknąć zjawiska ładowania się wersji zawartej w *cache*) oraz poprzez weryfikację statusu wirtualnego serwera poprzez interfejs WWW platformy BIG-IP i wbudowanego systemu typu Health-Check.

Dodatkowo podczas testów, weryfikowane jest obciążenie samego serwera aplikacyjnego z poziomu systemu operacyjnego, wykorzystując narzędzie *htop*.

V.2. Badanie odporności serwera bez systemów ochrony

W ramach testu referencyjnego, dokonano próby ataku DoS bezpośrednio na serwer aplikacji, obserwując przy tym zmiany w obciążeniu serwera oraz dostępności serwowanej przez niego aplikacji internetowej. W tym celu przełączono tymczasowo maszynę wirtualną z systemem Kali Linux do sieci *internal* tak, aby mogła się skomunikować bezpośrednio z serwerem, omijając system zabezpieczeń F5. Badanie symuluje zatem sytuację sprzed wprowadzenia systemu ochrony.

Jako próbę kontrolną wczytano 10 razy aplikację, odnosząc się bezpośrednio do serwera WWW oraz zmierzono czasy ładowania witryny za pomocą inspektora przeglądarki Firefox.



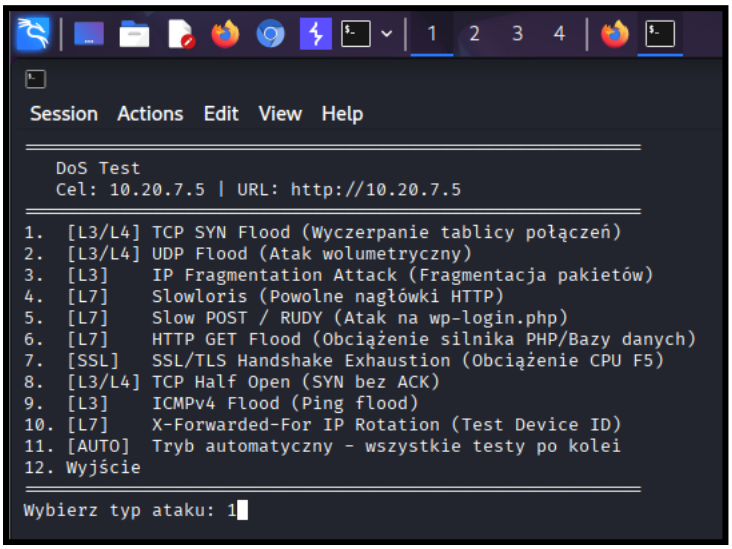
Rys. 29. Próba kontrolna wczytania strony bezpośrednio z serwera WWW

(źródło: opracowanie własne)

Zmierzony czas ładowania wyniósł średnio 4,91 sekundy.

V.2.1. Podatność na ataki w warstwie L3 i L4

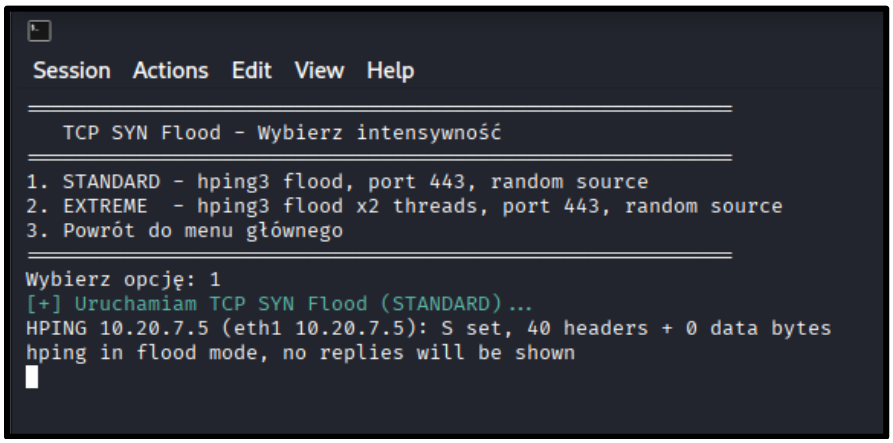
Posługując się uprzednio opisywanym skryptem dla systemu Linux, wykonano serię ataków DoS w warstwach sieciowej i transportowej. Do tych ataków zaliczały się: TCP SYN Flood, mające na celu wyczerpanie tablicy połączeń, UDP Flood, IP Fragmentation, TCP Half Open oraz ICMPv4 Flood. Każdy test przeprowadzono kolejno po sobie, przez 2 minuty, z 2-minutowymi przerwami pomiędzy.



Rys. 30. Interfejs skryptu do wykonywania testowych ataków DoS

(źródło: opracowanie własne)

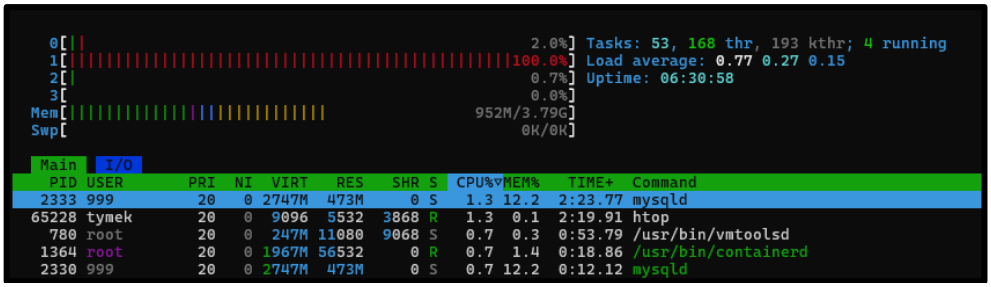
Wybierając odpowiednie opcje w menu, uruchamiano kolejno testy: 1, 2, 3, 8 oraz 9. Jako pierwszy wykonano atak TCP SYN Flood.



Rys. 31. Uruchomienie ataku TCP SYN Flood bezpośrednio na serwer

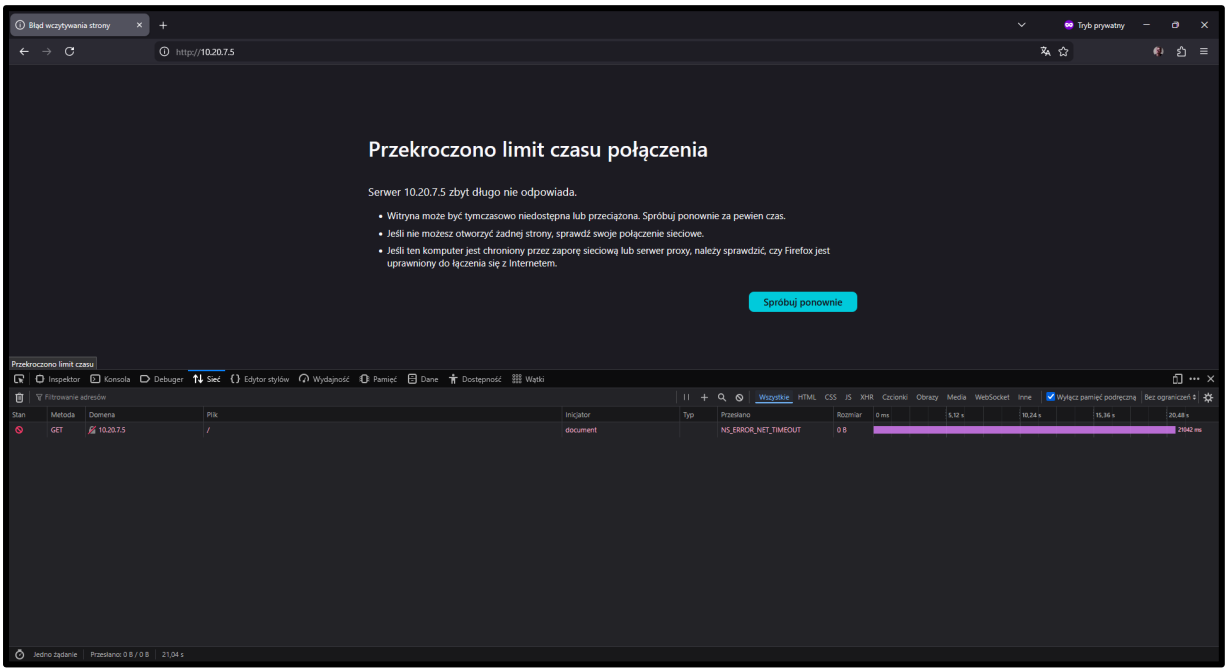
(źródło: opracowanie własne)

Skutki wykonania ataku były natychmiastowe – serwer od razu został przeciążony (o czym świadczy nagły wzrost wykorzystania zasobów, widoczny w narzędziu *htop*), a serwowana aplikacja przestała się wczytywać w oknie przeglądarki internetowej.



Rys. 32. Wzrost obciążenia serwera wskutek ataku TCP SYN Flood

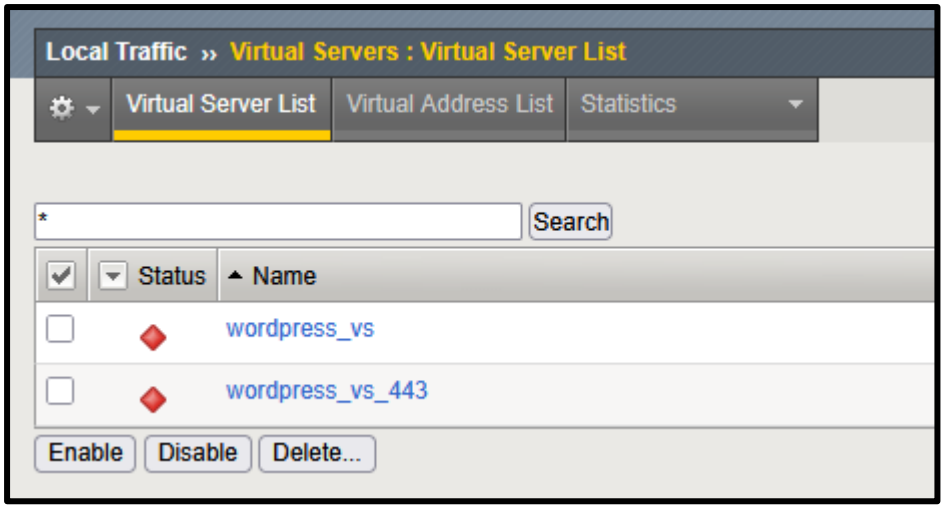
(źródło: opracowanie własne)



Rys. 33. Zrzut ekranu odmowy usługi aplikacji

(źródło: opracowanie własne)

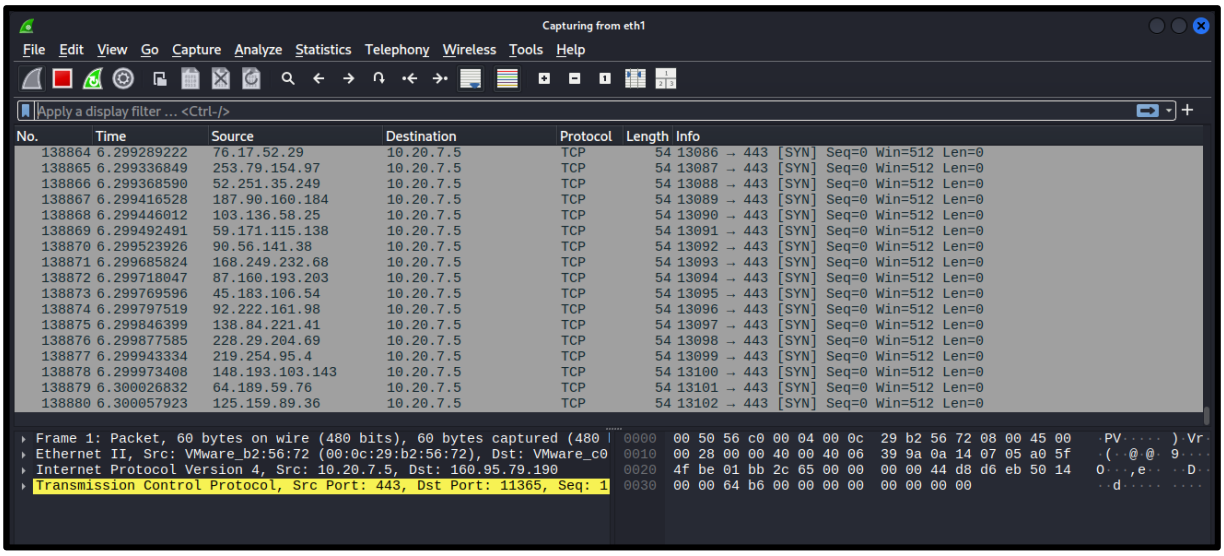
W celach kontrolnych, potwierdzono status serwera przy pomocy monitorów serwerów wirtualnych w BIG-IP. Czerwony romb widoczny na rysunku 33 świadczy o tym, że system nie zdołał połączyć się z serwerem implikując fakt, że jest on niedostępny.



Rys. 34. Weryfikacja niedostępności serwera z poziomu BIG-IP

(źródło: opracowanie własne)

Analiza zrzutu PCAP wykonanego przy pomocy programu Wireshark również wskazuje skalę ataku – wykonane zostały setki tysięcy żądań w bardzo krótkim czasie, co potwierdza dużą skuteczność ataku, kosztem niewielkiego obciążenia (system atakujący pozostawał dalej responsywny).



Rys. 35. Zapis analizatora Wireshark podczas wykonywania ataku TCP SYN Flood

(źródło: opracowanie własne)

Podczas testów wykonano również pozostałe sprawdzenia w ramach warstw L3/L4 – tj. atak UDP Flood, IP Fragmentation, TCP Half Open oraz ICMPv4 Flood. Rezultaty były zbieżne z poprzednim testem. We wszystkich przypadkach nastąpiło natychmiastowe wysycenie dostępnych zasobów serwera, co poskutkowało zaprzestaniem ładowania się aplikacji oraz oznaczeniem serwera jako niedostępnego przez mechanizmy monitorujące platformy BIG-IP. Ze względu na powtarzalność wyników, odstąpiono od prezentacji szczegółowej dokumentacji zdjęciowej dla każdego testowanego przypadku. Zbiorcze zestawienie wyników testów obciążeniowych bez systemu ochrony zaprezentowano w Tabeli 1.

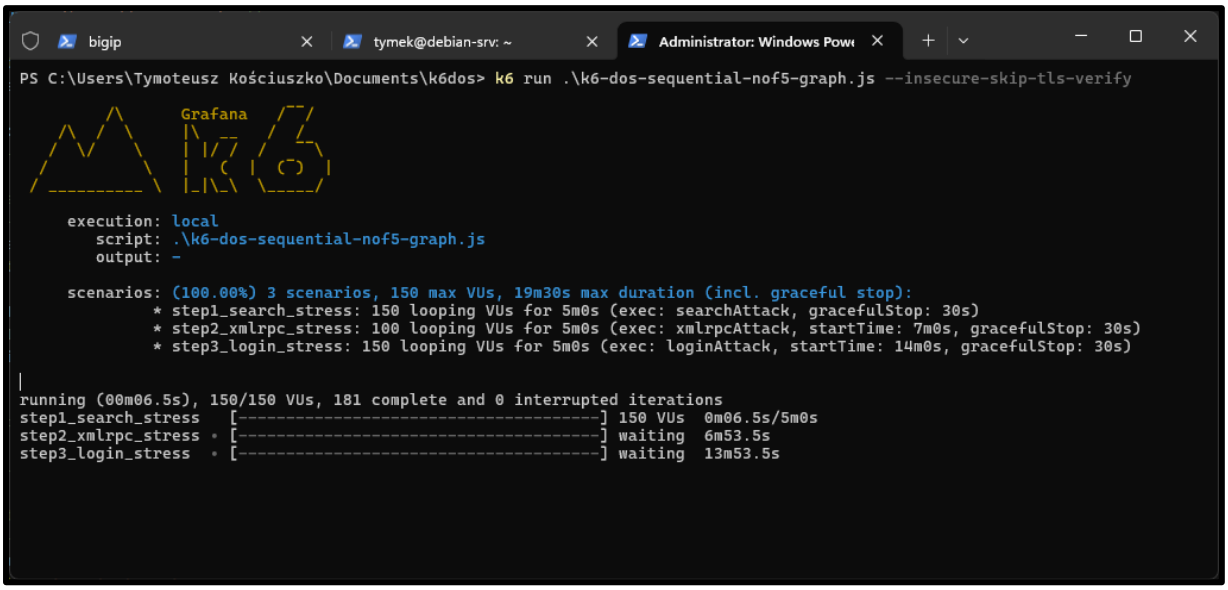
Tab. 1. Tabela wyników testów ataku DoS w warstwie L3/L4 na serwer aplikacji

Wektor ataku	Użycie CPU serwera	Dostępność usługi WWW	Szacowany czas do awarii
TCP SYN Flood	100%	Niedostępna	17 s
UDP Flood	100%	Niedostępna	20 s
IP Fragmentation	95-100%	Niedostępna	24 s
TCP Half Open	100%	Niedostępna	20 s
ICMPv4 Flood	100%	Niedostępna	21 s

(źródło: opracowanie własne)

V.2.2. Podatność na ataki w warstwie L7

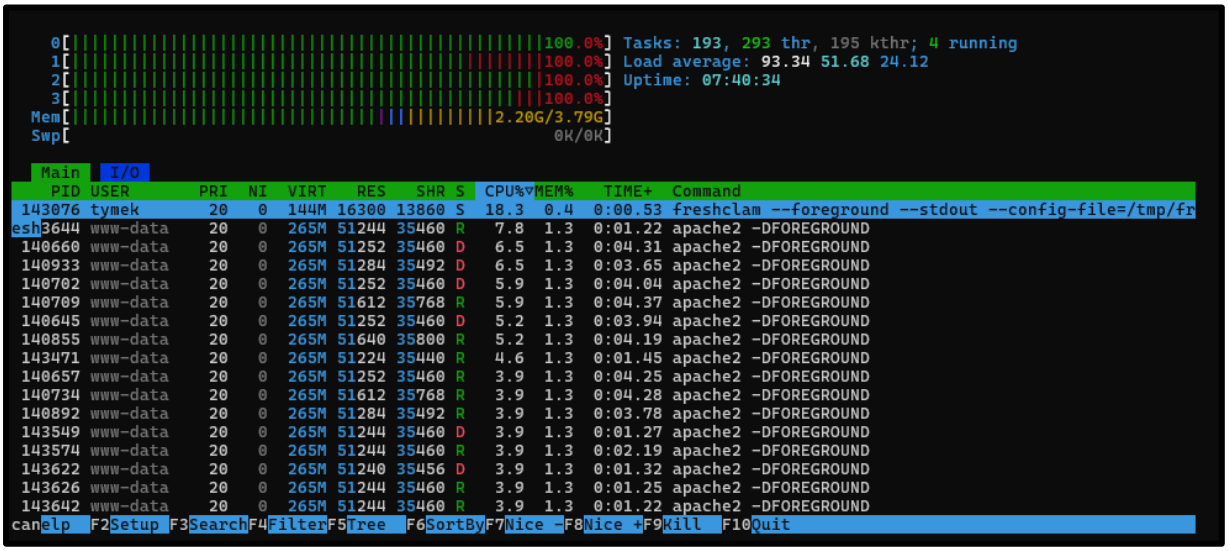
Ataki w warstwie aplikacyjnej zrealizowano posługując się skryptem testowym dla systemu Linux oraz narzędziem k6. Podczas próby przeprowadzono ataki Low and Slow, korzystając z funkcji numer 4 i 5 wykorzystywanego skryptu oraz uruchomiono skrypt *k6-dos-sequential-nof5.js* korzystający z narzędzia k6. Poniżej udokumentowano przebieg ataku przy pomocy zautomatyzowanego skryptu.



Rys. 36. Uruchomienie ataku HTTP Flood w środowisku Grafana K6

(źródło: opracowanie własne)

Tym razem obciążenie serwera było znacznie większe niż poprzednio, zużywając niemalże wszystkie jego zasoby – do tego stopnia, że serwer odmawiał reakcji na wydawane polecenia i komendy systemowe.



Rys. 37. Obciążenie serwera wskutek ataku HTTP Flood

(źródło: opracowanie własne)

Funkcjonowanie serwera, jak i witryny WordPress, zależne było od atakowanego celu – podczas ataku na endpointy /?s= oraz /wp-login.php witryna stawała się niedostępna dla użytkownika, a monitory serwerów wirtualnych BIG-IP potwierdzały ten stan. Z kolei w momencie testowania adresu /xmlrpc.php, zużycie zasobów serwera nadal pozostawało na maksymalnym poziomie, aczkolwiek dostępność witryny była niejednoznaczna – w losowych momentach serwer zwracał odpowiedź (co ważne, po dłuższym czasie niż standardowo – ok. 25 sekund względem początkowych maksymalnie 5 sekund), a mechniazmy weryfikujące BIG-IP wskazywały na

dostępność aplikacji. Można zatem wnioskować, że przy większym wolumenie obciążenia, atak ten również spowodowałby pełną odmowę działania usługi.

Atak obciążeniowy Low and Slow zwrócił z kolei zupełnie inne rezultaty, skutkujące jednak tym samym – brakiem dostępności aplikacji. Podczas wykonywania testu serwer aplikacyjny nie był w żaden sposób obciążony, poziom utylizacji procesora utrzymywał się na typowym poziomie bezczynności, wahając się w granicach 1-3%. Wynika to z istoty ataku typu Low and Slow – zamiast jednocześnie wysycać zasoby serwera wieloma zapytaniami, wymagającymi uruchomienia interpretera PHP, nawiązania połączenia z bazą MySQL oraz wykonania innych, kosztownych operacji obliczeniowych, otwarte zostało dużo równoległych połączeń sesji TCP, wyczerpując tym samym limit jednoczesnych połączeń serwera Apache. Wysyłane żądania były niekompletne, co wymuszało podtrzymywanie ich jako aktywnych i tym samym prowadziło do wyczerpania limitu i niedostępności usługi.

Wyniki przeprowadzonych testów w warstwie aplikacyjnej bez dodatkowego systemu ochrony zestawiono w formie tabeli (Tabela 2). W celu zapewnienia czytelności prezentowanych danych posłużono się skrótem „L&S” w miejsce pełnej nazwy „Low and Slow”.

Tab. 2. Tabela wyników testów ataku DoS w warstwie L7 na serwer aplikacji

Wektor ataku	Użyte narzędzie	Użycie CPU serwera	Dostępność usługi WWW	Szacowany czas do awarii
L&S Slow Headers	Skrypt SH (opcja Extreme)	1-3%	Niedostępna	18 s
L&S POST/RUDY	Skrypt SH	100%	Niedostępna	22 s
HTTP Flood /?s	Skrypt k6	100%	Niedostępna	23 s
HTTP Flood xmlrpc.php	Skrypt k6	100%	Utrudniona/niedostępna	n/d
HTTP Flood wp-login.php	Skrypt k6	100%	Niedostępna	20 s

(źródło: opracowanie własne)

V.3. Badanie skuteczności mitygacji ataków DoS z wykorzystaniem F5 BIG-IP

Mając na uwadze dotychczas uzyskane wyniki testów, które potwierdziły całkowitą bezbronność serwera aplikacyjnego wobec przeciążeniowych ataków wolumetrycznych i aplikacyjnych, przystąpiono do weryfikacji zaprojektowanego i wdrożonego systemu ochrony. W niniejszym podrozdziale ponownie zrealizowano opisane wcześniej scenariusze ataków przy jednoczesnej zmianie celu – złośliwy ruch skierowano na adres serwera wirtualnego (VIP) urządzenia F5 BIG-IP, pośredniczącego w komunikacji z serwerem aplikacyjnym, a tym samym zabezpieczającym go przed potencjalnym agresorem.

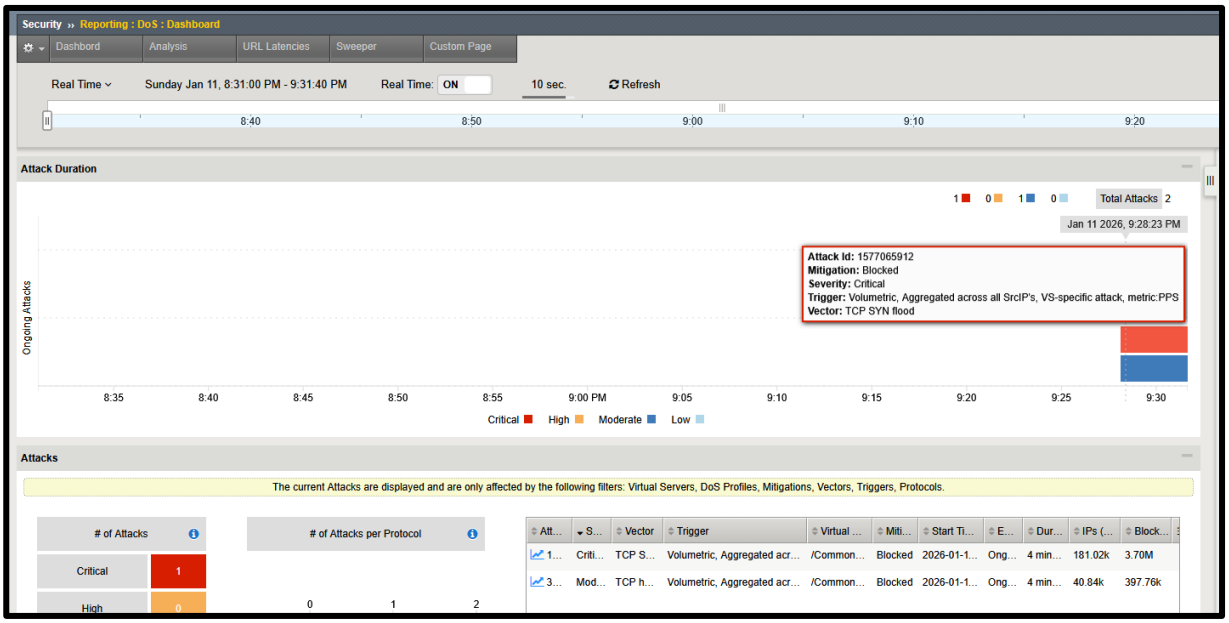
W związku z powyższym ponownie wyznaczono próbę kontrolną, w postaci wczytania 10 razy aplikacji w przeglądarce internetowej użytkownika końcowego (z wyłączonym cache'owaniem). Z próby tej wyznaczono średni czas od wysłania pierwszego żądania, do pełnego załadowania witryny. Czas ten wyniósł 19,23 sekundy. Należy przy tym wyróżnić dwa główne powody tak znacznego spowolnienia działania zwirtualizowanej infrastruktury teleinformatycznej. Po pierwsze: wykorzystywana maszyna wirtualna F5 BIG-IP z licencją w wersji laboratoryjnej (*Lab License*) ogranicza przepustowość łącza do 10 Mb/s, co znacząco wpływa na prędkość odbieranych i wysyłanych danych. Po drugie: zwirtualizowane środowisko wykorzystywane do generowania próbnych ataków jest ograniczone wydajnościowo, co spowodowane jest koniecznością uruchomienia wszystkich wykorzystywanych maszyn wirtualnych na przeciętnej klasy stacji roboczej. Wobec tego zrezygnowano z mierzenia czasów wczytywania aplikacji WordPress podczas ataków, jako iż w omawianym przypadku uzyskiwane wartości nie byłyby miarodajne. Należy mieć na uwadze, że w środowisku produkcyjnym, tj. z odseparowanym urządzeniem serwera i platformy BIG-IP, oraz stosując pełną licencję niezawierającą ograniczeń przepustowości, faktyczne czasy wczytywania aplikacji prawdopodobnie byłyby znacznie szybsze.

Założeniem niniejszych testów jest zatem sprawdzenie poprawnej mitygacji ataków DoS na różne warstwy modelu OSI, przy jednoczesnym zapewnieniu ciągłej dostępności aplikacji dla innych, tzw. legalnych hostów. W przypadku tego testu legalnym klientem jest maszyna z zainstalowanym systemem Kali Linux oraz system Windows 11 uruchomiony na urządzeniu jako system hosta (oba systemu podłączone są do sieci *external*, symulując ruch przychodzący z zewnątrz infrastruktury). W zależności od wykonywanego testu (skrypt BASH uruchamiany jest w systemie Linux, skrypt k6 – w systemie Windows) dostępność aplikacji podlega za każdym razem sprawdzeniu z poziomu drugiego systemu operacyjnego, na którym w danym momencie nie uruchomiono żadnych automatów generujących ruch przeciążeniowy.

V.3.1. Test ataku w warstwie L3 i L4

W ramach niniejszych testów przeprowadzono analogiczne ataki na testowaną aplikację webową, względem tych z punktu V.2.1. W dalszej części opisano przykład zrealizowania ataku TCP SYN Flood.

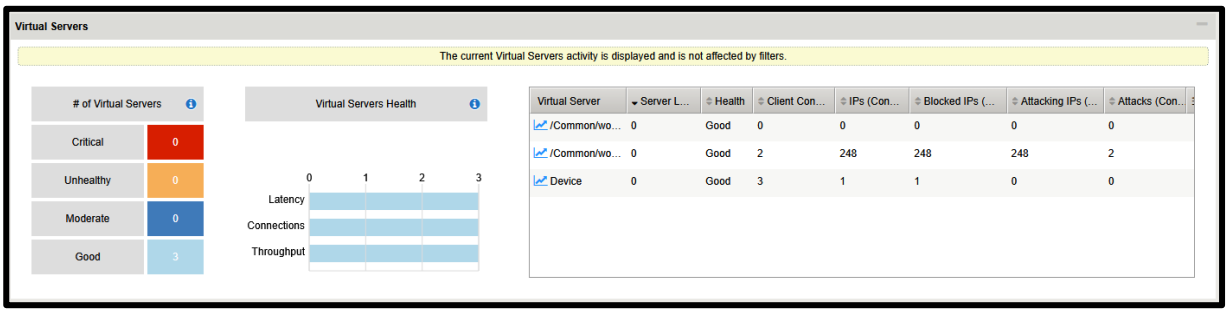
Wykonano polecenie 1. ze skryptu Bash, wykonując tym samym opisywany test. Tym razem zaobserwowano wzmożony ruch sieciowy w dzienniku zdarzeń sekcji *DoS Protection*, związany z wykonywanym atakiem. Platforma skutecznie wykryła oraz zablokowała atak, oznaczając go rangą krytycznego, co widać w panelu *DoS Dashboard*.



Rys. 38. Ekran DoS Dashboard BIG-IP obrazujący wykryte ataki DoS

(źródło: opracowanie własne)

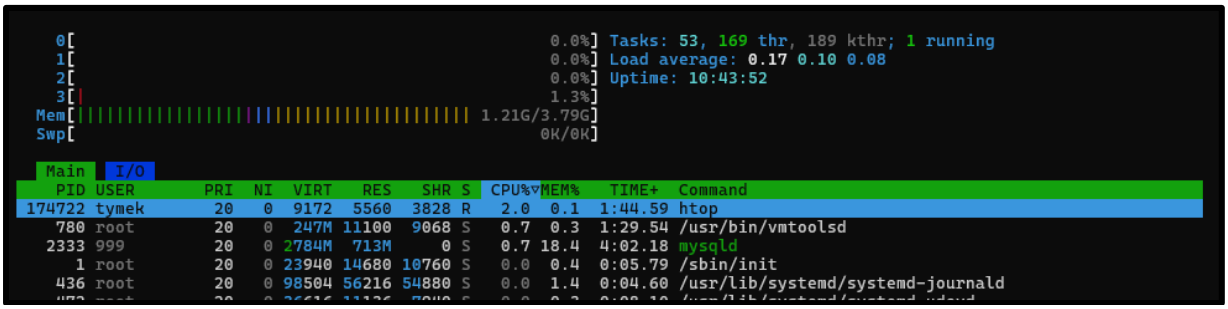
Należy także zaznaczyć, że wśród uzyskanych wyników zaobserwowano również, że wdrożona platforma BIG-IP jest skuteczna w blokowaniu szkodliwego ruchu sieciowego nawet pomimo pozornie różnych źródłowych adresów IP. System BIG-IP poprawnie zablokował wszystkie połączenia związane z tym atakiem.



Rys. 39. Fragment DoS Dashboard ukazujący liczbę zablokowanych adresów IP

(źródło: opracowanie własne)

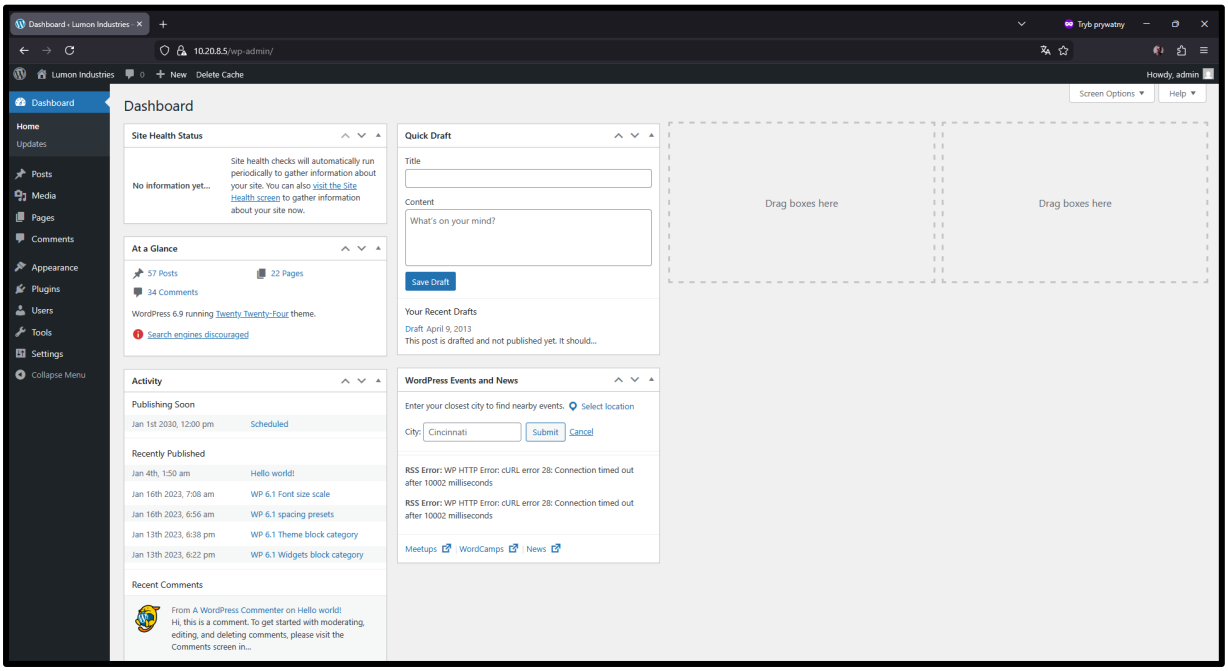
Podczas ataku i jego mitygacji utylizacja zasobów serwera pozostała na tym samym poziomie – cały ciężar ataku przejęło rozwiązanie BIG-IP.



Rys. 40. Zasoby serwera podczas trwania ataku DoS wraz z ochroną

(źródło: opracowanie własne)

Dodatkową formę weryfikacji działania aplikacji internetowej podczas trwania ataku stanowiło dokonanie próby zalogowania się użytkownika w witrynie WordPress oraz załadowanie Kokpitu systemu WordPress – jednego z bardziej wymagających i interaktywnych zasobów, wymagającego nieustannego przesyłania wielu jednoczesnych zapytań do serwera aplikacyjnego.



Rys. 41. Kokpit WordPress wczytany w trakcie ataku wolumetrycznego

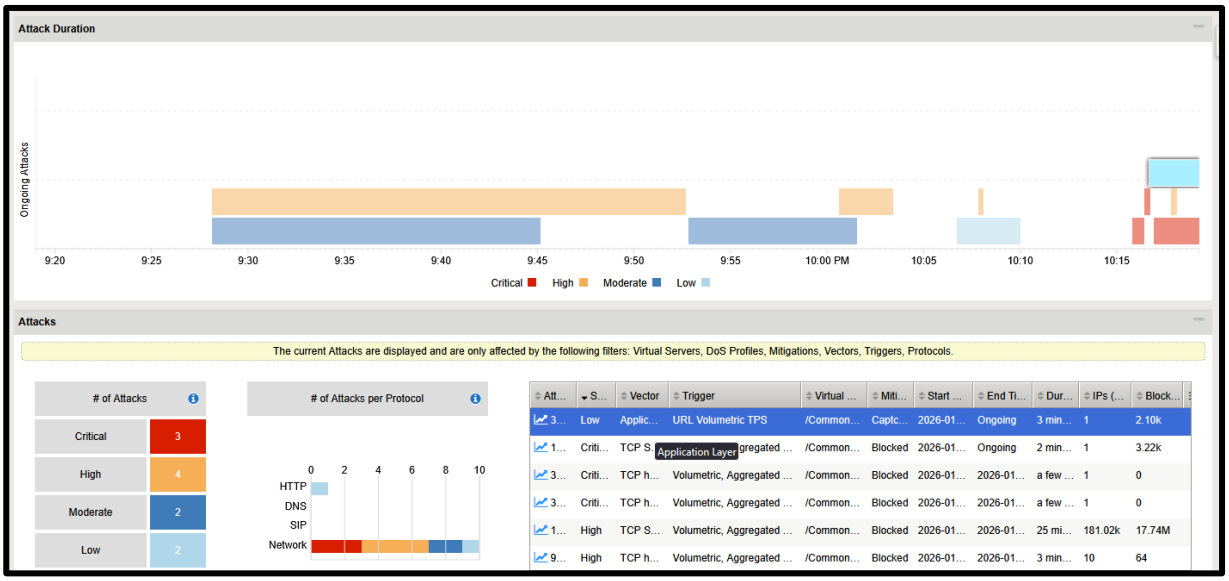
(źródło: opracowanie własne)

W wyniku przeprowadzenia wszystkich pozostałych ataków testowych (tj. UDP Flood, IP Fragmentation, TCP Half Open oraz ICMPv4 Flood) uzyskano te same, pozytywne rezultaty – za każdym razem BIG-IP skutecznie odpierało zagrożenie, jednocześnie nie blokując dostępu do chronionej aplikacji.

V.3.2. Test ataku w warstwie L7

Analogicznie jak w poprzednim przypadku, wykonano ponowne testowe ataki DoS w warstwie aplikacyjnej, jako źródło wskazując adres serwera wirtualnego (obiekt VIP) BIG-IP. W ramach przykładu zaprezentowano wykonanie ataku HTTP Flood za pomocą skryptu k6 – identycznie, jak w V.2.2., wówczas bez ochrony systemu WAF.

Przez pierwsze kilka sekund od rozpoczęcia ataku, można było zaobserwować wzmożone obciążenie serwera aplikacyjnego, które ustało w momencie neutralizacji ataku przez platformę BIG-IP. Ataki w warstwie aplikacyjnej zostały poprawnie wykryte, zablokowane oraz zaraportowane przez wdrożony system ochrony.



Rys. 42. Ekran DoS Dashboard obrazujący atak na warstwę aplikacyjną (L7)

(źródło: opracowanie własne)

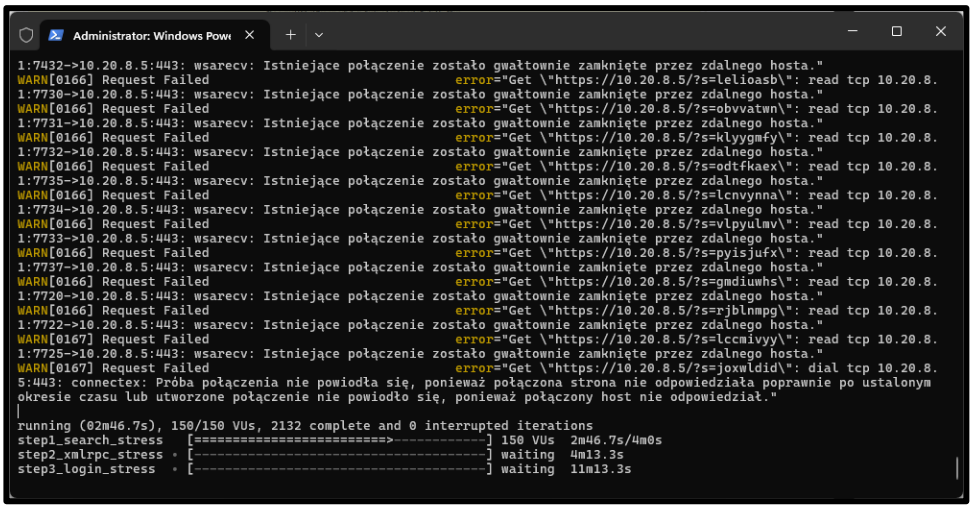
Ponadto należy zaznaczyć, że również atak na zasób */xmlrpc.php* został poprawnie zmitygowany, tym razem poprzez autorski skrypt iRule, co zaobserwowano podczas analizy dzienników zdarzeń modułu LTM w interfejsie WWW platformy BIG-IP, a także poprzez połączenie SSH.

```
Jan 11 22:22:36 bigip.local info tmm4[18340]: Rule /Common/wp-xmlrpc-protection <HTTP_REQUEST>: DoS Alert: IP 10.20.8.1 przekroczyl limit zapytan do xmlrpc.php (49/5). Blokowanie.
Jan 11 22:22:36 bigip.local info tmm2[18340]: Rule /Common/wp-xmlrpc-protection <HTTP_REQUEST>: DoS Alert: IP 10.20.8.1 przekroczyl limit zapytan do xmlrpc.php (49/5). Blokowanie.
Jan 11 22:22:36 bigip.local info tmm3[18340]: Rule /Common/wp-xmlrpc-protection <HTTP_REQUEST>: DoS Alert: IP 10.20.8.1 przekroczyl limit zapytan do xmlrpc.php (49/5). Blokowanie.
Jan 11 22:22:36 bigip.local info tmm5[18340]: Rule /Common/wp-xmlrpc-protection <HTTP_REQUEST>: DoS Alert: IP 10.20.8.1 przekroczyl limit zapytan do xmlrpc.php (49/5). Blokowanie.
Jan 11 22:22:36 bigip.local info tmm[18340]: Rule /Common/wp-xmlrpc-protection <HTTP_REQUEST>: DoS Alert: IP 10.20.8.1 przekroczyl limit zapytan do xmlrpc.php (49/5). Blokowanie.
Jan 11 22:22:36 bigip.local info tmm[18340]: Rule /Common/wp-xmlrpc-protection <HTTP_REQUEST>: DoS Alert: IP 10.20.8.1 przekroczyl limit zapytan do xmlrpc.php (56/5). Blokowanie.
Jan 11 22:22:36 bigip.local info tmm1[18340]: Rule /Common/wp-xmlrpc-protection <HTTP_REQUEST>: DoS Alert: IP 10.20.8.1 przekroczyl limit zapytan do xmlrpc.php (49/5). Blokowanie.
Jan 11 22:22:36 bigip.local info tmm3[18340]: Rule /Common/wp-xmlrpc-protection <HTTP_REQUEST>: DoS Alert: IP 10.20.8.1 przekroczyl limit zapytan do xmlrpc.php (57/5). Blokowanie.
Jan 11 22:22:36 bigip.local info tmm1[18340]: Rule /Common/wp-xmlrpc-protection <HTTP_REQUEST>: DoS Alert: IP 10.20.8.1 przekroczyl limit zapytan do xmlrpc.php (58/5). Blokowanie.
Jan 11 22:22:36 bigip.local info tmm4[18340]: Rule /Common/wp-xmlrpc-protection <HTTP_REQUEST>: DoS Alert: IP 10.20.8.1 przekroczyl limit zapytan do xmlrpc.php (58/5). Blokowanie.
Jan 11 22:22:36 bigip.local info tmm2[18340]: Rule /Common/wp-xmlrpc-protection <HTTP_REQUEST>: DoS Alert: IP 10.20.8.1 przekroczyl limit zapytan do xmlrpc.php (60/5). Blokowanie.
Jan 11 22:22:36 bigip.local info tmm5[18340]: Rule /Common/wp-xmlrpc-protection <HTTP_REQUEST>: DoS Alert: IP 10.20.8.1 przekroczyl limit zapytan do xmlrpc.php (61/5). Blokowanie.
[root@bigip:Active:Standalone] config #
```

Rys. 43. Logi LTM obrazujące poprawne działanie skryptu mitygującego iRules

(źródło: opracowanie własne)

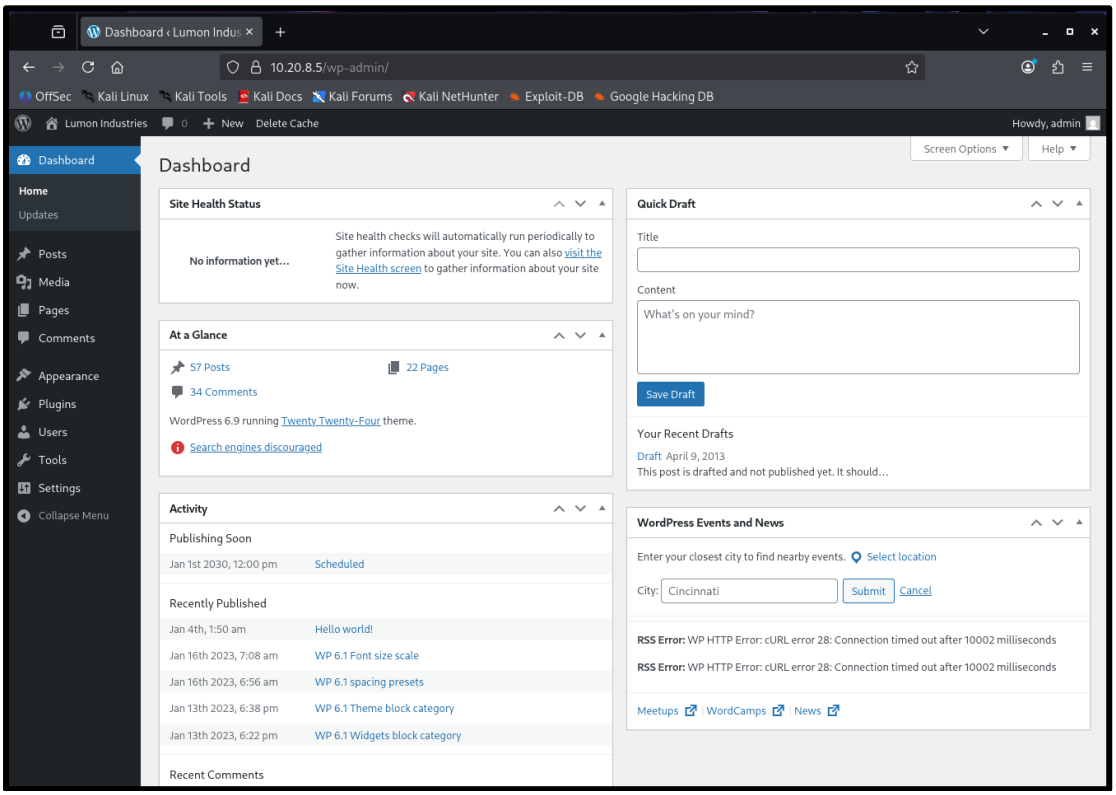
We wszystkich trzech omawianych przypadkach dostrzeżono aktywne blokowanie wrogich połączeń, o czym świadczą komunikaty błędów narzędzia k6 dotyczące zamknięcia połączenia przez zdalnego hosta podczas trwania próby testowej.



Rys. 44. Komunikaty błędów testu k6 świadczące o poprawności działania blokady

(źródło: opracowanie własne)

Dostępność aplikacji WordPress podczas trwania ataku testowego zweryfikowano łącząc się z nią z poziomu systemu Kali Linux (który w tym scenariuszu pełni rolę legalnego klienta, zamiast atakującego). Próba ta w każdym przypadku zakończyła się sukcesem, co potwierdza prawidłową mitygację trwającego ataku.



Rys. 45. Kokpit WordPress wczytany w trakcie trwania ataku na warstwę aplikacji

(źródło: opracowanie własne)

Analogicznie jak w poprzednim punkcie, przetestowano również odporność rozwiązania na inne, wcześniej testowane ataki (Low and Slow – Slow Headers oraz Low and Slow – POST), co ostatecznie potwierdziło skuteczność opracowanego w ramach niniejszej pracy systemu ochrony przed atakami DoS.

Wnioski końcowe

Niniejsza praca inżynierska poświęcona została analizie zagrożeń typu *Denial of Service* oraz praktycznej implementacji mechanizmów obronnych z wykorzystaniem platformy F5 BIG-IP. Głównym celem projektu było zaprojektowanie, wdrożenie i weryfikacja skuteczności systemu ochrony dla aplikacji webowej opartej na systemie *WordPress*, która w konfiguracji domyślnej wykazywała wysoką podatność na ataki tego rodzaju.

Przeprowadzone badania eksperymentalne, podzielone na etapy testów sprzed i po wdrożeniu ochrony, jednoznacznie potwierdziły słuszność przyjętych założeń projektowych. W pierwszej fazie wykazano, że serwer aplikacyjny pozbawiony dedykowanej ochrony ulega natychmiastowej awarii w obliczu nawet prostych ataków wolumetrycznych oraz aplikacyjnych, co prowadziło do całkowitego wyczerpania zasobów CPU lub limitów połączeń.

Wdrożenie urządzenia F5 BIG-IP oraz konfiguracja modułów AFM i ASM pozwoliły na skuteczną mitygację zidentyfikowanych zagrożeń. Zastosowanie mechanizmów obronnych wymienionych modułów, w tym limitowanie pasma, weryfikacja przeglądarki oraz *CAPTCHA* umożliwiło zachowanie ciągłości działania chronionej usługi, nawet w trakcie aktywnego ataku.

Dowiedziono również, że system jest gotowy do dalszej modyfikacji i rozwoju – technologia skryptów *iRules* stanowi idealny nośnik do szybkiego wdrażania niestandardowych sygnatur bezpieczeństwa, wynikających z potencjalnych, nowych wektorów ataków, lub z własnych, spersonalizowanych potrzeb.

Istotnym elementem procesu badawczego była identyfikacja ograniczeń wynikających ze specyfiki środowiska laboratoryjnego. Wirtualizacja całej infrastruktury testowej na pojedynczej stacji roboczej oraz techniczne ograniczenia licencji laboratoryjnej urządzenia F5 uniemożliwiły przeprowadzenie testów wydajnościowych na większą skalę. Bariery te wymusiły na potrzeby testów znaczne obniżenie progów detekcji, co jednak nie wpłynęło na ocenę logicznej poprawności działania mechanizmów obronnych. Zrealizowany scenariusz stanowił skuteczne przedstawienie koncepcji działającego rozwiązania.

Wnioski płynące z realizacji pracy wskazują na konieczność odmiennego podejścia do kalibracji systemu w potencjalnym środowisku produkcyjnym. Przy realnym wdrożeniu wartości progowe dla detekcji i mitygacji powinny zostać wielokrotnie zwiększone i dostosowane do typowej charakterystyki ruchu, aby uniknąć wywoływania fałszywych alarmów i blokowania legalnego ruchu. Ponadto, zalecaną praktyką jest szersze wykorzystanie trybów automatycznej nauki, które w niniejszej pracy zastąpiono konfiguracją manualną na potrzeby precyzyjnego wyzwalania ataków.

Reasumując, cel pracy został osiągnięty – zaprojektowany i zbadany system ochrony skutecznie odseparował ruch szkodliwy od legalnego, udowadniając, że zastosowanie zaawansowanych narzędzi typu WAF jest niezbędnym elementem strategii bezpieczeństwa współczesnych usług internetowych.

Bibliografia

[1] MAGLARAS, Leandros, Ioanna KANTZAVELOU i Mohamed Amine FERRAG, red. *Cyber Security of Critical Infrastructures*. Basel, Switzerland: MDPI - Multidisciplinary Digital Publishing Institute, 2021. ISBN 978-3-0365-2726-0.

[2] KIRUTHIKA, Jay, Souheil KHADDAJ, Darrel GREENHILL i Jarek FRANCIK. User Experience Design in Web Applications. W: *2016 19th IEEE Intl Conference on Computational Science and Engineering (CSE), IEEE 14th Intl Conference on Embedded and Ubiquitous Computing (EUC), and 15th Intl Symposium on Distributed Computing and Applications for Business Engineering (DCABES)*: *2016 IEEE Intl Conference on Computational Science and Engineering (CSE) and IEEE Intl Conference on Embedded and Ubiquitous Computing (EUC) and 15th Intl Symposium on Distributed Computing and Applications for Business Engineering (DCABES)* [online]. Paris: IEEE, 2016, s. 642–646 [dostęp. 2026-01-08]. ISBN 978-1-5090-3593-9. Dostępne na: doi:10.1109/CSE-EUC-DCABES.2016.253

[3] *OWASP Foundation, the Open Source Foundation for Application Security | OWASP Foundation* [online]. [dostęp. 2026-01-08]. Dostępne na: https://owasp.org/

[4] *Denial of Service | OWASP Foundation* [online]. [dostęp. 2026-01-09]. Dostępne na: https://owasp.org/www-community/attacks/Denial_of_Service

[5] KUMAR, Gulshan. Denial of service attacks – an updated perspective. *Systems Science & Control Engineering* [online]. 2016, **4**(1), 285–294. ISSN 2164-2583. Dostępne na: doi:10.1080/21642583.2016.1241193

[6] DAR, Ashaq Hussain, Beenish HABIB, Farida KHURSHID i M. Tariq BANDAY. Experimental analysis of DDoS attack and it's detection in Eucalyptus private cloud platform. W: *2016 International Conference on Advances in Computing, Communications and Informatics (ICACCI)*: *2016 International Conference on Advances in Computing, Communications and Informatics (ICACCI)* [online]. Jaipur, India: IEEE, 2016, s. 1718–1724 [dostęp. 2026-01-09]. ISBN 978-1-5090-2029-4. Dostępne na: doi:10.1109/ICACCI.2016.7732295

[7] PRASEED, Amit i P. Santhi THILAGAM. DDoS Attacks at the Application Layer: Challenges and Research Perspectives for Safeguarding Web Applications. *IEEE Communications Surveys & Tutorials* [online]. 2019, **21**(1), 661–685. ISSN 1553-877X, 2373-745X. Dostępne na: doi:10.1109/COMST.2018.2870658

[8] *Denial of Service - OWASP Cheat Sheet Series* [online]. [dostęp. 2026-01-09]. Dostępne na: https://cheatsheetseries.owasp.org/cheatsheets/Denial_of_Service_Cheat_Sheet.html

[9] Cloudflare DDoS Protection. *Cloudflare Docs* [online]. 22. września 2025 [dostęp. 2026-01-09]. Dostępne na: https://developers.cloudflare.com/ddos-protection/

[10] Prolexic - Comprehensive DDoS Attack Protection. *Akamai* [online]. [dostęp. 2026-01-09]. Dostępne na: https://www.akamai.com/resources/product-brief/prolexic

[11] *How AWS Shield and Shield Advanced work - AWS WAF, AWS Firewall Manager, AWS Shield Advanced, and AWS Shield network security director* [online]. [dostęp. 2026-01-09]. Dostępne na: https://docs.aws.amazon.com/waf/latest/developerguide/ddos-overview.html

[12] *Advanced DDoS Defense and Attack Mitigation | DefensePro* [online]. [dostęp. 2026-01-09]. Dostępne na: https://www.radware.com/products/defensepro/

[13] *The founding of F5* [online]. [dostęp. 2026-01-10]. Dostępne na: https://my.f5.com/manage/s/article/K245

[14] KUMAR, Vikas i BISINFOTECH. F5 Recognized as the Leader for WAF by Gartner in Magic Quadrant. *Bisinfotech* [online]. 18. sierpnia 2017 [dostęp. 2026-01-10]. Dostępne na: https://www.bisinfotech.com/f5-recognized-as-the-leader-for-waf-by-gartner-in-magic-quadrant/

[15] F5 Networks Named a Leader in Gartner Magic Quadrant for Application Delivery Controllers for 10th Consecutive Year. *F5, Inc.* [online]. [dostęp. 2026-01-10]. Dostępne na: https://www.f5.com/company/news/press-releases/f5-networks-named-a-leader-in-gartner-magic-quadrant-for-application-delivery-controllers-for-10th-consecutive-year

[16] LACA, Andra. F5 Reigns Gartner's Application Delivery Controller Magic Quadrant. *Adapture* [online]. 9. lutego 2015 [dostęp. 2026-01-10]. Dostępne na: https://adapture.com/f5-reigns-supreme-remains-leader-gartners-application-delivery-controller-magic-quadrant/

[17] Akamai Blog | Akamai Named a Gartner Magic Quadrant Leader for Web Application and API Protection. *Akamai* [online]. [dostęp. 2026-01-16]. Dostępne na: https://www.akamai.com/blog/news/akamai-named-a-gartner-magic-quadrant-leader-for-web-application-and-api-protection

[18] F5 Named a Leader in the IDC MarketScape: Worldwide Web Application and API Protection Enterprise Platforms 2024 Vendor Assessment. *F5, Inc.* [online]. [dostęp. 2026-01-10]. Dostępne na: https://www.f5.com/go/report/f5-named-a-leader-in-the-idc-marketscape-worldwide-web-application-and-api-protection-enterprise-platforms-2024-vendor-assessment

[19] F5 | Multicloud Security and Application Delivery. *F5, Inc.* [online]. [dostęp. 2026-01-10]. Dostępne na: https://www.f5.com

Spis rysunków

Rys. 1. Schemat ataku DDoS ... 8
Rys. 2. Wizualizacja raportu Gartner Magic Quadrant for WAF (2017) ... 16
Rys. 3. Wizualizacja raportu Gartner Magic Quadrant for WAAP (2021) ... 16
Rys. 4. Urządzenie F5 BIG-IP, model r10900 ... 18
Rys. 5. Schemat logiczny dotychczasowej infrastruktury sieciowej firmy ... 21
Rys. 6. Schemat logiczny infrastruktury firmy po wdrożeniu rozwiązania BIG-IP ... 24
Rys. 7. Wstępny ekran konfiguracyjny BIG-IP ... 25
Rys. 8. Ekran wyboru modułów BIG-IP ... 26
Rys. 9. Ekran konfiguracji sieci VLAN ... 26
Rys. 10. Ekran konfiguracji adresów IP (Self-IPs) ... 26
Rys. 11. Test osiągalności BIG-IP z poziomu serwera ... 27
Rys. 12. Ekran konfiguracji węzłów serwerów WWW ... 27
Rys. 13. Ekran konfiguracji puli ... 27
Rys. 14. Konfiguracja polityki LTM przekierowującej ruch HTTP do HTTPS ... 28
Rys. 15. Ekran konfiguracji wirtualnych serwerów ... 28
Rys. 16. Ekran zarządzania certyfikatami SSL/TLS wraz z utworzonym certyfikatem ... 29
Rys. 17. Konfiguracja profilu SSL ... 29
Rys. 18. Zrzut ekranu poprawnie wczytanej aplikacji internetowej ... 30
Rys. 19. Ekran konfiguracji podstawowych opcji polityki ochrony przed DoS ... 31
Rys. 20. Panel ustawień grupy ataków HTTP w polityce ochrony przed DoS ... 32
Rys. 21. Ekran ustawień wektorów ataków warstwy L7 ... 33
Rys. 22. Konfiguracja wymaganej polityki Bot Defense ... 34
Rys. 23. Panel ustawień grupy ataków *Network* w polityce ochrony przed DoS ... 35
Rys. 24. Ekran ustawień wektorów ataków warstw L3/L4 ... 36
Rys. 25. Fragment ekranu konfiguracji ochrony BIG-IP przed atakami DoS ... 37
Rys. 26. Zrzut ekranu kodu skryptu iRule blokującego połączenia z *xmlrpc.php* ... 38
Rys. 27. Ekran przypisywania skryptów iRules do serwera wirtualnego ... 39
Rys. 28. Ekran konfiguracji profilu logowania dla serwera wirtualnego ... 39
Rys. 29. Próba kontrolna wczytania strony bezpośrednio z serwera WWW ... 41

Rys. 30. Interfejs skryptu do wykonywania testowych ataków DoS....42
Rys. 31. Uruchomienie ataku TCP SYN Flood bezpośrednio na serwer 42
Rys. 32. Wzrost obciążenia serwera wskutek ataku TCP SYN Flood....42
Rys. 33. Zrzut ekranu odmowy usługi aplikacji 43
Rys. 34. Weryfikacja niedostępności serwera z poziomu BIG-IP....43
Rys. 35. Zapis analizatora Wireshark podczas wykonywania ataku TCP SYN Flood....44
Rys. 36. Uruchomienie ataku HTTP Flood w środowisku Grafana K6 45
Rys. 37. Obciążenie serwera wskutek ataku HTTP Flood....45
Rys. 38. Ekran DoS Dashboard BIG-IP obrazujący wykryte ataki DoS 48
Rys. 39. Fragment DoS Dashboard ukazujący liczbę zablokowanych adresów IP....48
Rys. 40. Zasoby serwera podczas trwania ataku DoS wraz z ochroną....49
Rys. 41. Kokpit WordPress wczytany w trakcie ataku wolumetrycznego 49
Rys. 42. Ekran DoS Dashboard obrazujący atak na warstwę aplikacyjną (L7) 50
Rys. 43. Logi LTM obrazujące poprawne działanie skryptu mitygującego iRules....50
Rys. 44. Komunikaty błędów testu k6 świadczące o poprawności działania blokady....51
Rys. 45. Kokpit WordPress wczytany w trakcie trwania ataku na warstwę aplikacji....51

Spis tabel

Tab. 1. Tabela wyników testów ataku DoS w warstwie L3/L4 na serwer aplikacji....44
Tab. 2. Tabela wyników testów ataku DoS w warstwie L7 na serwer aplikacji 46

Załączniki

1. Płyta CD/DVD zawierająca:
    a. Konfigurację dla platformy BIG-IP (wersja 17.x)
    b. Skrypt *dos-test.sh* dla Linux (testy DoS L3/L4/L7)
    c. Plik tekstowy *wp-xmlrpc-protection-irule.txt* (skrypt iRule chroniący endpoint *xmlrpc.php*)
    d. Plik ZIP *k6dos.zip* ze skryptami dla narzędzia Grafana k6 (testy DoS endpointów)